Windows 11 STIG Compliance Report

Benchmark: Microsoft_Windows_11_STIG Release 6 | Scan Date: 2026-02-09 22:31:29 | Host: PYTHO-MCWL-001 | Auto-Fix: ENABLED | Total Rules: 550

4 checks were auto-remediated. A REBOOT may be required for all changes to take effect.

189	4	0	338	19
Passed	Auto-Fixed	Failed	Manual	N/A

All Results

Vuln ID	Rule ID	Sev.	Status	Rule Title	Details / Fix Action
V-253254	WN11-00-000005	medium	**N/A**	Domain-joined systems must use Windows 11 Enterprise Edition 64-bit version	System is not domain-joined (standalone).
V-253255	WN11-00-000010	medium	**N/A**	Windows 11 domain-joined systems must have a TPM enabled	System is not domain-joined.
V-253256	WN11-00-000015	medium	**Pass**	Windows 11 systems must have UEFI firmware and run in UEFI mode	Firmware type: UEFI (verified via Secure Boot state)
V-253257	WN11-00-000020	medium	**Pass**	Secure Boot must be enabled on Windows 11 systems	Secure Boot is enabled.
V-253258	WN11-00-000025	medium	**Manual**	Windows 11 must employ automated mechanisms for flaw remediation (ESS)	Cannot auto-fix - requires DOD-approved ESS software installation and ISSM documentation.
V-253259	WN11-00-000030	high	**Pass**	Windows 11 must use BitLocker to encrypt all disks	All volumes are BitLocker protected.
V-253260	WN11-00-000031	high	**Pass**	Windows 11 systems must use a BitLocker PIN for pre-boot authentication	UseAdvancedStartup=1, UseTPMPIN=1, UseTPMKeyPIN=1

V-253261	WN11-00-000032	medium	**Pass**	Windows 11 systems must use a BitLocker PIN with a minimum length of six digits	MinimumPIN=6 (>= 6)
V-253262	WN11-00-000035	medium	**Pass**	The OS must employ a deny-all, permit-by-exception policy (AppLocker)	WDAC policy files found in CodeIntegrity\CiPolicies\Active (7 policies).
V-253263	WN11-00-000040	high	**Pass**	Windows 11 systems must be maintained at a supported servicing level	Version: 25H2, Build: 26200.7623
V-253264	WN11-00-000045	high	**Pass**	The Windows 11 system must use an antivirus program	Antivirus detected and running: Windows Defender
V-253265	WN11-00-000050	high	**Pass**	Local volumes must be formatted using NTFS	All local volumes use NTFS.
V-253266	WN11-00-000055	medium	**Manual**	Alternate operating systems must not be permitted on the same system	2 boot entries found. Cannot auto-fix safely - verify no alternate OS is installed.
V-253267	WN11-00-000060	medium	**N/A**	Non-system-created file shares must limit access	Only system-created shares exist.
V-253268	WN11-00-000065	low	**Pass**	Unused accounts must be disabled or removed after 35 days of inactivity	No enabled accounts inactive > 35 days.
V-253269	WN11-00-000070	high	**Manual**	Only accounts responsible for administration must have Administrator rights	Members: PYTHO-MCWL-001\Administrator, PYTHO-MCWL-001\pytho-mcwl. Cannot auto-fix - requires organizational review.
V-253270	WN11-00-000075	medium	**Pass**	Only backup accounts must be members of the Backup Operators group	Backup Operators group is empty.
V-253271	WN11-00-000080	medium	**Pass**	Only authorized accounts in Hyper-V Administrators group	Hyper-V Administrators group is empty.
V-253272	WN11-00-000085	low	**N/A**	Standard local user accounts must not exist on a system in a domain	System is not domain-joined.
V-253273	WN11-00-000090	medium	**Pass**	Accounts must be configured to require password expiration	No active accounts have 'Password never expires'.
V-253275	WN11-00-000100	high	**Pass**	IIS or its subcomponents must not be installed on a workstation	IIS is not installed.
V-253276	WN11-00-000105	medium	**Pass**	SNMP must not be installed on the system	SNMP is not installed.

V-253277	WN11-00-000110	medium	Pass	Simple TCP/IP Services must not be installed on the system	Simple TCP/IP Services is not installed.
V-253278	WN11-00-000115	medium	Pass	The Telnet Client must not be installed on the system	Telnet Client is not installed.
V-253279	WN11-00-000120	medium	Pass	The TFTP Client must not be installed on the system	TFTP Client is not installed.
V-253280	WN11-00-000130	medium	Pass	Software certificate installation files must be removed from Windows 11	No .p12 or .pfx files found.
V-253281	WN11-00-000135	medium	Pass	A host-based firewall must be installed and enabled	Windows Firewall is enabled on all profiles.
V-253282	WN11-00-000140	medium	Manual	Inbound exceptions to the firewall must only allow authorized remote management hosts	Cannot auto-fix - requires organizational review of authorized management host IPs.
V-253285	WN11-00-000155	medium	N/A	The Windows PowerShell 2.0 feature must be disabled	Windows 11 version 24H2 or newer.
V-253286	WN11-00-000160	medium	Pass	The SMBv1 protocol must be disabled on the system	SMB1Protocol feature is Disabled.
V-253287	WN11-00-000165	medium	N/A	The SMBv1 protocol must be disabled on the SMB server	SMBv1 disabled via feature (WN11-00-000160).
V-253288	WN11-00-000170	medium	N/A	The SMBv1 protocol must be disabled on the SMB client	SMBv1 disabled via feature (WN11-00-000160).
V-253289	WN11-00-000175	medium	Pass	The Secondary Logon service must be disabled on Windows 11	Secondary Logon: Disabled and not Running.
V-253290	WN11-00-000190	medium	Manual	Orphaned SIDs must be removed from user rights	Cannot auto-fix - requires manual review of User Rights Assignment.
V-253291	WN11-00-000210	medium	N/A	Bluetooth must be turned off unless approved by the organization	No Bluetooth hardware detected.
V-253293	WN11-00-000230	medium	N/A	The system must notify the user when a Bluetooth device attempts to connect	Bluetooth not present or disabled.
V-253294	WN11-00-000240	high	Manual	Administrative accounts must not be used with	Cannot auto-fix - requires organizational policy and AppLocker/allowlisting configuration.

				applications that access the internet	
V-253295	WN11-00-000250	medium	**N/A**	Windows 11 nonpersistent VM sessions must not exceed 24 hours	Verify if this is a nonpersistent VM. If so, ensure sessions <= 24 hours.
V-253296	WN11-00-000260	low	**Manual**	The Windows 11 time service must synchronize with an appropriate DOD time source	Standalone system - verify NTP is configured to an authorized time source.
V-253297	WN11-AC-000005	medium	**Fixed**	Windows 11 account lockout duration must be configured to 15 minutes or greater	Policy configured via net accounts. *Fix Applied: net accounts /lockoutduration:15*
V-253298	WN11-AC-000010	medium	**Pass**	The number of allowed bad logon attempts must be configured to three or less	Lockout threshold: 3
V-253299	WN11-AC-000015	medium	**Fixed**	The period of time before the bad logon counter is reset must be 15 minutes	Policy configured via net accounts. *Fix Applied: net accounts /lockoutwindow:15*
V-253300	WN11-AC-000020	medium	**Pass**	The password history must be configured to 24 passwords remembered	Length of password history maintained: 24
V-253301	WN11-AC-000025	medium	**Fixed**	The maximum password age must be configured to 60 days or less	Policy configured via net accounts. *Fix Applied: net accounts /maxpwage:60*
V-253302	WN11-AC-000030	medium	**Fixed**	The minimum password age must be configured to at least 1 day	Policy configured via net accounts. *Fix Applied: net accounts /minpwage:1*
V-253303	WN11-AC-000035	medium	**Pass**	Passwords must, at a minimum, be 14 characters	Minimum password length: 14
V-253304	WN11-AC-000040	medium	**Pass**	The built-in Microsoft password complexity filter must be enabled	PasswordComplexity=1 (Enabled)
V-253305	WN11-AC-000045	high	**Pass**	Reversible password encryption must be disabled	ClearTextPassword=0 (Disabled)
V-253306	WN11-AU-000005	medium	**Pass**	Audit Credential Validation failures	Credential Validation - Failure is configured.
V-253307	WN11-AU-000010	medium	**Pass**	Audit Credential Validation successes	Credential Validation - Success is configured.
V-253308	WN11-AU-000030	medium	**Pass**	Audit Security Group Management successes	Security Group Management - Success is configured.

V-253309	WN11-AU-000035	medium	**Pass**	Audit User Account Management failures	User Account Management - Failure is configured.
V-253310	WN11-AU-000040	medium	**Pass**	Audit User Account Management successes	User Account Management - Success is configured.
V-253311	WN11-AU-000045	medium	**Pass**	Audit PNP Activity successes	Plug and Play Events - Success is configured.
V-253312	WN11-AU-000050	medium	**Pass**	Audit Process Creation successes	Process Creation - Success is configured.
V-253313	WN11-AU-000054	medium	**Pass**	Audit Account Lockout failures	Account Lockout - Failure is configured.
V-253314	WN11-AU-000060	medium	**Pass**	Audit Group Membership successes	Group Membership - Success is configured.
V-253315	WN11-AU-000065	medium	**Pass**	Audit Logoff successes	Logoff - Success is configured.
V-253316	WN11-AU-000070	medium	**Pass**	Audit Logon failures	Logon - Failure is configured.
V-253317	WN11-AU-000075	medium	**Pass**	Audit Logon successes	Logon - Success is configured.
V-253318	WN11-AU-000080	medium	**Pass**	Audit Special Logon successes	Special Logon - Success is configured.
V-253319	WN11-AU-000081	medium	**Pass**	Audit File Share failures	File Share - Failure is configured.
V-253320	WN11-AU-000082	medium	**Pass**	Audit File Share successes	File Share - Success is configured.
V-253321	WN11-AU-000083	medium	**Pass**	Audit Other Object Access Events successes	Other Object Access Events - Success is configured.
V-253322	WN11-AU-000084	medium	**Pass**	Audit Other Object Access Events failures	Other Object Access Events - Failure is configured.
V-253323	WN11-AU-000085	medium	**Pass**	Audit Removable Storage failures	Removable Storage - Failure is configured.

V-253324	WN11-AU-000090	medium	**Pass**	Audit Removable Storage successes	Removable Storage - Success is configured.
V-253325	WN11-AU-000100	medium	**Pass**	Audit Policy Change - Audit Policy Change successes	Audit Policy Change - Success is configured.
V-253326	WN11-AU-000105	medium	**Pass**	Audit Policy Change - Authentication Policy Change successes	Authentication Policy Change - Success is configured.
V-253327	WN11-AU-000107	medium	**Pass**	Audit Policy Change - Authorization Policy Change successes	Authorization Policy Change - Success is configured.
V-253328	WN11-AU-000110	medium	**Pass**	Audit Privilege Use - Sensitive Privilege Use failures	Sensitive Privilege Use - Failure is configured.
V-253329	WN11-AU-000115	medium	**Pass**	Audit Privilege Use - Sensitive Privilege Use successes	Sensitive Privilege Use - Success is configured.
V-253330	WN11-AU-000120	medium	**Pass**	Audit System - IPsec Driver failures	IPsec Driver - Failure is configured.
V-253331	WN11-AU-000130	medium	**Pass**	Audit System - Other System Events successes	Other System Events - Success is configured.
V-253332	WN11-AU-000135	medium	**Pass**	Audit System - Other System Events failures	Other System Events - Failure is configured.
V-253333	WN11-AU-000140	medium	**Pass**	Audit System - Security State Change successes	Security State Change - Success is configured.
V-253334	WN11-AU-000150	medium	**Pass**	Audit System - Security System Extension successes	Security System Extension - Success is configured.
V-253335	WN11-AU-000155	medium	**Pass**	Audit System - System Integrity failures	System Integrity - Failure is configured.
V-253336	WN11-AU-000160	medium	**Pass**	Audit System - System Integrity successes	System Integrity - Success is configured.
V-253344	WN11-AU-000555	medium	**Pass**	Audit Other Policy Change Events failures	Other Policy Change Events - Failure is configured.
V-253345	WN11-AU-000560	medium	**Pass**	Audit Other Logon/Logoff Events successes	Other Logon/Logoff Events - Success is configured.

V-253346	WN11-AU-000565	medium	**Pass**	Audit Other Logon/Logoff Events failures	Other Logon/Logoff Events - Failure is configured.
V-253347	WN11-AU-000570	medium	**Pass**	Audit Detailed File Share failures	Detailed File Share - Failure is configured.
V-253348	WN11-AU-000575	medium	**Pass**	Audit MPSSVC Rule-Level Policy Change successes	MPSSVC Rule-Level Policy Change - Success is configured.
V-253349	WN11-AU-000580	medium	**Pass**	Audit MPSSVC Rule-Level Policy Change failures	MPSSVC Rule-Level Policy Change - Failure is configured.
V-253274	WN11-00-000095	medium	**Pass**	Permissions for system files and directories must conform to minimum requirements.	EveryoneIncludesAnonymous=0 (Expected: 0)
V-253284	WN11-00-000150	high	**Pass**	Structured Exception Handling Overwrite Protection (SEHOP) must be enabled.	DisableExceptionChainValidation=0 (Expected: 0)
V-253337	WN11-AU-000500	medium	**Pass**	The Application event log size must be configured to 32768 KB or greater.	MaxSize=32768 (Expected: 32768)
V-253338	WN11-AU-000505	medium	**Pass**	The Security event log size must be configured to 1024000 KB or greater.	MaxSize=1024000 (Expected: 1024000)
V-253339	WN11-AU-000510	medium	**Pass**	The System event log size must be configured to 32768 KB or greater.	MaxSize=32768 (Expected: 32768)
V-253350	WN11-CC-000005	medium	**Pass**	Camera access from the lock screen must be disabled.	NoLockScreenCamera=1 (Expected: 1)
V-253352	WN11-CC-000010	medium	**Pass**	The display of slide shows on the lock screen must be disabled.	NoLockScreenSlideshow=1 (Expected: 1)
V-253353	WN11-CC-000020	medium	**Pass**	IPv6 source routing must be configured to highest protection.	DisableIpSourceRouting=2 (Expected: 2)
V-253354	WN11-CC-000025	medium	**Pass**	The system must be configured to prevent IP source routing.	DisableIPSourceRouting=2 (Expected: 2)
V-253355	WN11-CC-000030	low	**Pass**	The system must be configured to prevent Internet Control Message Protocol (ICMP) redirects from overriding Open Shortes	EnableICMPRedirect=0 (Expected: 0)

V-253356	WN11-CC-000035	low	**Pass**	The system must be configured to ignore NetBIOS name release requests except from WINS servers.	NoNameReleaseOnDemand=1 (Expected: 1)
V-253357	WN11-CC-000037	medium	**Pass**	Local administrator accounts must have their privileged token filtered to prevent elevated privileges from being used ov	LocalAccountTokenFilterPolicy=0 (Expected: 0)
V-253358	WN11-CC-000038	medium	**Pass**	WDigest Authentication must be disabled.	UseLogonCredential=0 (Expected: 0)
V-253360	WN11-CC-000040	medium	**Pass**	Insecure logons to an SMB server must be disabled.	AllowInsecureGuestAuth=0 (Expected: 0)
V-253361	WN11-CC-000044	medium	**Pass**	Internet connection sharing must be disabled.	NC_ShowSharedAccessUI=0 (Expected: 0)
V-253364	WN11-CC-000055	medium	**Pass**	Simultaneous connections to the internet or a Windows domain must be limited.	fMinimizeConnections=3 (Expected: 3)
V-253365	WN11-CC-000060	medium	**Pass**	Connections to non-domain networks when connected to a domain authenticated network must be blocked.	fBlockNonDomain=1 (Expected: 1)
V-253366	WN11-CC-000065	medium	**Pass**	Wi-Fi Sense must be disabled.	AutoConnectAllowedOEM=0 (Expected: 0)
V-253367	WN11-CC-000066	medium	**Pass**	Command line data must be included in process creation events.	ProcessCreationIncludeCmdLine_Enabled=1 (Expected: 1)
V-253368	WN11-CC-000068	medium	**Pass**	Windows 11 must be configured to enable Remote host allows delegation of non-exportable credentials.	AllowProtectedCreds=1 (Expected: 1)
V-253369	WN11-CC-000070	medium	**Pass**	Virtualization-based Security must be enabled on Windows 11 with the platform security level configured to Secure Boot o	EnableVirtualizationBasedSecurity=1 (Expected: 1)
V-253370	WN11-CC-000075	high	**Pass**	Credential Guard must be running on Windows 11 domain-joined systems.	LsaCfgFlags=1 (Expected: 1)

V-253371	WN11-CC-000080	medium	**Pass**	Virtualization-based protection of code integrity must be enabled.	HypervisorEnforcedCodeIntegrity=1 (Expected: 1)
V-253372	WN11-CC-000085	medium	**Pass**	Early Launch Antimalware, Boot-Start Driver Initialization Policy must prevent boot drivers.	DriverLoadPolicy=1 (Expected: 1)
V-253373	WN11-CC-000090	medium	**Pass**	Group Policy objects must be reprocessed even if they have not changed.	NoGPOListChanges=0 (Expected: 0)
V-253374	WN11-CC-000100	medium	**Pass**	Downloading print driver packages over HTTP must be prevented.	DisableWebPnPDownload=1 (Expected: 1)
V-253375	WN11-CC-000105	medium	**Pass**	Web publishing and online ordering wizards must be prevented from downloading a list of providers.	NoWebServices=1 (Expected: 1)
V-253376	WN11-CC-000110	medium	**Pass**	Printing over HTTP must be prevented.	DisableHTTPPrinting=1 (Expected: 1)
V-253377	WN11-CC-000115	medium	**Pass**	Systems must at least attempt device authentication using certificates.	DevicePKInitEnabled=1 (Expected: 1)
V-253378	WN11-CC-000120	medium	**Pass**	The network selection user interface (UI) must not be displayed on the logon screen.	DontDisplayNetworkSelectionUI=1 (Expected: 1)
V-253379	WN11-CC-000130	medium	**Pass**	Local users on domain-joined computers must not be enumerated.	EnumerateLocalUsers=0 (Expected: 0)
V-253380	WN11-CC-000145	medium	**Pass**	Users must be prompted for a password on resume from sleep (on battery).	DCSettingIndex=1 (Expected: 1)
V-253381	WN11-CC-000150	medium	**Pass**	The user must be prompted for a password on resume from sleep (plugged in).	ACSettingIndex=1 (Expected: 1)
V-253382	WN11-CC-000155	high	**Pass**	Solicited Remote Assistance must not be allowed.	fAllowToGetHelp=0 (Expected: 0)
V-253383	WN11-CC-000165	medium	**Pass**	Unauthenticated RPC clients must be restricted from connecting to the RPC server.	RestrictRemoteClients=1 (Expected: 1)

V-253384	WN11-CC-000170	low	**Pass**	The setting to allow Microsoft accounts to be optional for modern style apps must be enabled.	MSAOptional=1 (Expected: 1)
V-253385	WN11-CC-000175	low	**Pass**	The Application Compatibility Program Inventory must be prevented from collecting data and sending the information to Mi	DisableInventory=1 (Expected: 1)
V-253386	WN11-CC-000180	high	**Pass**	Autoplay must be turned off for non-volume devices.	NoAutoplayfornonVolume=1 (Expected: 1)
V-253387	WN11-CC-000185	high	**Pass**	The default autorun behavior must be configured to prevent autorun commands.	NoAutorun=1 (Expected: 1)
V-253388	WN11-CC-000190	high	**Pass**	Autoplay must be disabled for all drives.	NoDriveTypeAutoRun=255 (Expected: 255)
V-253389	WN11-CC-000195	medium	**Pass**	Enhanced anti-spoofing for facial recognition must be enabled on Windows 11.	EnhancedAntiSpoofing=1 (Expected: 1)
V-253390	WN11-CC-000197	low	**Pass**	Microsoft consumer experiences must be turned off.	DisableWindowsConsumerFeatures=1 (Expected: 1)
V-253391	WN11-CC-000200	medium	**Pass**	Administrator accounts must not be enumerated during elevation.	EnumerateAdministrators=0 (Expected: 0)
V-253392	WN11-CC-000204	medium	**Pass**	Enhanced diagnostic data must be limited to the minimum required to support Windows Analytics.	LimitEnhancedDiagnosticDataWindowsAnalytics=1 (Expected: 1)
V-253393	WN11-CC-000205	medium	**Pass**	Windows Telemetry must not be configured to Full.	AllowTelemetry=0 (Expected: 0)
V-253394	WN11-CC-000206	low	**Pass**	Windows Update must not obtain updates from other PCs on the internet.	DODownloadMode=0 (Expected: 0)
V-253394	WN11-CC-000206	low	**Pass**	Windows Update must not obtain updates from other PCs on the internet.	DODownloadMode=0 (Expected: 0)
V-253395	WN11-CC-000210	medium	**Pass**	The Microsoft Defender SmartScreen for Explorer must be enabled.	EnableSmartScreen=1 (Expected: 1)

V-253396	WN11-CC-000215	medium	**Pass**	Explorer Data Execution Prevention must be enabled.	NoDataExecutionPrevention=0 (Expected: 0)
V-253397	WN11-CC-000220	low	**Pass**	File Explorer heap termination on corruption must be disabled.	NoHeapTerminationOnCorruption=0 (Expected: 0)
V-253398	WN11-CC-000225	medium	**Pass**	File Explorer shell protocol must run in protected mode.	PreXPSP2ShellProtocolBehavior=0 (Expected: 0)
V-253399	WN11-CC-000252	medium	**Pass**	Windows 11 must be configured to disable Windows Game Recording and Broadcasting.	AllowGameDVR=0 (Expected: 0)
V-253400	WN11-CC-000255	medium	**Pass**	The use of a hardware security device with Windows Hello for Business must be enabled.	RequireSecurityDevice=1 (Expected: 1)
V-253401	WN11-CC-000260	medium	**Pass**	Windows 11 must be configured to require a minimum pin length of six characters or greater.	MinimumPINLength=6 (Expected: 6)
V-253402	WN11-CC-000270	medium	**Pass**	Passwords must not be saved in the Remote Desktop Client.	DisablePasswordSaving=1 (Expected: 1)
V-253403	WN11-CC-000275	medium	**Pass**	Local drives must be prevented from sharing with Remote Desktop Session Hosts.	fDisableCdm=1 (Expected: 1)
V-253404	WN11-CC-000280	medium	**Pass**	Remote Desktop Services must always prompt a client for passwords upon connection.	fPromptForPassword=1 (Expected: 1)
V-253405	WN11-CC-000285	medium	**Pass**	The Remote Desktop Session Host must require secure RPC communications.	fEncryptRPCTraffic=1 (Expected: 1)
V-253406	WN11-CC-000290	medium	**Pass**	Remote Desktop Services must be configured with the client connection encryption set to the required level.	MinEncryptionLevel=3 (Expected: 3)
V-253407	WN11-CC-000295	medium	**Pass**	Attachments must be prevented from being downloaded from RSS feeds.	DisableEnclosureDownload=1 (Expected: 1)
V-253408	WN11-CC-000300	medium	**Pass**	Basic authentication for RSS feeds over HTTP must not be used.	AllowBasicAuthInClear=0 (Expected: 0)

V-253409	WN11-CC-000305	medium	**Pass**	Indexing of encrypted files must be turned off.	AllowIndexingEncryptedStoresOrItems=0 (Expected: 0)
V-253410	WN11-CC-000310	medium	**Pass**	Users must be prevented from changing installation options.	EnableUserControl=0 (Expected: 0)
V-253411	WN11-CC-000315	high	**Pass**	The Windows Installer feature `"Always install with elevated privileges`" must be disabled.	AlwaysInstallElevated=0 (Expected: 0)
V-253412	WN11-CC-000320	medium	**Pass**	Users must be notified if a web-based program attempts to install software.	SafeForScripting=0 (Expected: 0)
V-253413	WN11-CC-000325	medium	**Pass**	Automatically signing in the last interactive user after a system-initiated restart must be disabled.	DisableAutomaticRestartSignOn=1 (Expected: 1)
V-253414	WN11-CC-000326	medium	**Pass**	PowerShell script block logging must be enabled on Windows 11.	EnableScriptBlockLogging=1 (Expected: 1)
V-253415	WN11-CC-000327	medium	**Pass**	PowerShell Transcription must be enabled on Windows 11.	EnableTranscripting=1 (Expected: 1)
V-253416	WN11-CC-000330	high	**Pass**	The Windows Remote Management (WinRM) client must not use Basic authentication.	AllowBasic=0 (Expected: 0)
V-253417	WN11-CC-000335	medium	**Pass**	The Windows Remote Management (WinRM) client must not allow unencrypted traffic.	AllowUnencryptedTraffic=0 (Expected: 0)
V-253418	WN11-CC-000345	high	**Pass**	The Windows Remote Management (WinRM) service must not use Basic authentication.	AllowBasic=0 (Expected: 0)
V-253419	WN11-CC-000350	medium	**Pass**	The Windows Remote Management (WinRM) service must not allow unencrypted traffic.	AllowUnencryptedTraffic=0 (Expected: 0)
V-253420	WN11-CC-000355	medium	**Pass**	The Windows Remote Management (WinRM) service must not store RunAs credentials.	DisableRunAs=1 (Expected: 1)
V-253421	WN11-CC-000360	medium	**Pass**	The Windows Remote Management (WinRM) client must not use Digest authentication.	AllowDigest=0 (Expected: 0)

V-253422	WN11-CC-000365	medium	**Pass**	Windows 11 must be configured to prevent Windows apps from being activated by voice while the system is locked.	LetAppsActivateWithVoiceAboveLock=2 (Expected: 2)
V-253422	WN11-CC-000365	medium	**Pass**	Windows 11 must be configured to prevent Windows apps from being activated by voice while the system is locked.	LetAppsActivateWithVoice=2 (Expected: 2)
V-253426	WN11-EP-000310	medium	**Pass**	Windows 11 Kernel (Direct Memory Access) DMA Protection must be enabled.	DeviceEnumerationPolicy=0 (Expected: 0)
V-253434	WN11-SO-000015	medium	**Pass**	Local accounts with blank passwords must be restricted to prevent access from the network.	LimitBlankPasswordUse=1 (Expected: 1)
V-253437	WN11-SO-000030	medium	**Pass**	Audit policy using subcategories must be enabled.	SCENoApplyLegacyAuditPolicy=1 (Expected: 1)
V-253438	WN11-SO-000035	medium	**Pass**	Outgoing secure channel traffic must be encrypted or signed.	RequireSignOrSeal=1 (Expected: 1)
V-253439	WN11-SO-000040	medium	**Pass**	Outgoing secure channel traffic must be encrypted.	SealSecureChannel=1 (Expected: 1)
V-253440	WN11-SO-000045	medium	**Pass**	Outgoing secure channel traffic must be signed.	SignSecureChannel=1 (Expected: 1)
V-253441	WN11-SO-000050	low	**Pass**	The computer account password must not be prevented from being reset.	DisablePasswordChange=0 (Expected: 0)
V-253442	WN11-SO-000055	low	**Pass**	The maximum age for machine account passwords must be configured to 30 days or less.	MaximumPasswordAge=30 (Expected: 30)
V-253443	WN11-SO-000060	medium	**Pass**	The system must be configured to require a strong session key.	RequireStrongKey=1 (Expected: 1)
V-253444	WN11-SO-000070	medium	**Pass**	The machine inactivity limit must be set to 15 minutes, locking the system with the screensaver.	InactivityTimeoutSecs=900 (Expected: 900)
V-253447	WN11-SO-000085	low	**Pass**	Caching of logon credentials must be limited.	CachedLogonsCount=10 (Expected: 10)

V-253448	WN11-SO-000095	medium	**Pass**	The Smart Card removal option must be configured to Force Logoff or Lock Workstation.	SCRemoveOption=1 (Expected: 1)
V-253449	WN11-SO-000100	medium	**Pass**	The Windows SMB client must be configured to always perform SMB packet signing.	RequireSecuritySignature=1 (Expected: 1)
V-253450	WN11-SO-000110	medium	**Pass**	Unencrypted passwords must not be sent to third-party SMB Servers.	EnablePlainTextPassword=0 (Expected: 0)
V-253451	WN11-SO-000120	medium	**Pass**	The Windows SMB server must be configured to always perform SMB packet signing.	RequireSecuritySignature=1 (Expected: 1)
V-253453	WN11-SO-000145	high	**Pass**	Anonymous enumeration of SAM accounts must not be allowed.	RestrictAnonymousSAM=1 (Expected: 1)
V-253454	WN11-SO-000150	high	**Pass**	Anonymous enumeration of shares must be restricted.	RestrictAnonymous=1 (Expected: 1)
V-253455	WN11-SO-000160	medium	**Pass**	The system must be configured to prevent anonymous users from having the same rights as the Everyone group.	EveryoneIncludesAnonymous=0 (Expected: 0)
V-253456	WN11-SO-000165	high	**Pass**	Anonymous access to Named Pipes and Shares must be restricted.	RestrictNullSessAccess=1 (Expected: 1)
V-253458	WN11-SO-000180	medium	**Pass**	NTLM must be prevented from falling back to a Null session.	allownullsessionfallback=0 (Expected: 0)
V-253459	WN11-SO-000185	medium	**Pass**	PKU2U authentication using online identities must be prevented.	AllowOnlineID=0 (Expected: 0)
V-253460	WN11-SO-000190	medium	**Pass**	Kerberos encryption types must be configured to prevent the use of DES and RC4 encryption suites.	SupportedEncryptionTypes=2147483640 (Expected: 2147483640)
V-253461	WN11-SO-000195	high	**Pass**	The system must be configured to prevent the storage of the LAN Manager hash of passwords.	NoLMHash=1 (Expected: 1)
V-253462	WN11-SO-000205	high	**Pass**	The LanMan authentication level must be set to send NTLMv2 response only, and to refuse LM and NTLM.	LmCompatibilityLevel=5 (Expected: 5)

V-253463	WN11-SO-000210	medium	**Pass**	The system must be configured to the required LDAP client signing level.	LDAPClientIntegrity=1 (Expected: 1)
V-253464	WN11-SO-000215	medium	**Pass**	The system must be configured to meet the minimum session security requirement for NTLM SSP based clients.	NTLMMinClientSec=537395200 (Expected: 537395200)
V-253465	WN11-SO-000220	medium	**Pass**	The system must be configured to meet the minimum session security requirement for NTLM SSP based servers.	NTLMMinServerSec=537395200 (Expected: 537395200)
V-253466	WN11-SO-000230	medium	**Pass**	The system must be configured to use FIPS-compliant algorithms for encryption, hashing, and signing.	Enabled=1 (Expected: 1)
V-253467	WN11-SO-000240	low	**Pass**	The default permissions of global system objects must be increased.	ProtectionMode=1 (Expected: 1)
V-253468	WN11-SO-000245	medium	**Pass**	User Account Control approval mode for the built-in Administrator must be enabled.	FilterAdministratorToken=1 (Expected: 1)
V-253469	WN11-SO-000250	medium	**Pass**	User Account Control must prompt administrators for consent on the secure desktop.	ConsentPromptBehaviorAdmin=2 (Expected: 2)
V-253471	WN11-SO-000255	medium	**Pass**	User Account Control must automatically deny elevation requests for standard users.	ConsentPromptBehaviorUser=0 (Expected: 0)
V-253472	WN11-SO-000260	medium	**Pass**	User Account Control must be configured to detect application installations and prompt for elevation.	EnableInstallerDetection=1 (Expected: 1)
V-253473	WN11-SO-000265	medium	**Pass**	User Account Control must only elevate UIAccess applications that are installed in secure locations.	EnableSecureUIAPaths=1 (Expected: 1)
V-253474	WN11-SO-000270	medium	**Pass**	User Account Control must run all administrators in Admin Approval Mode, enabling UAC.	EnableLUA=1 (Expected: 1)
V-253475	WN11-SO-000275	medium	**Pass**	User Account Control must virtualize file and registry write failures to per-user locations.	EnableVirtualization=1 (Expected: 1)

V-279688	WN11-00-000126	medium	Pass	Windows 11 systems must block consumer account user authentication.	DisableUserAuth=1 (Expected: 1)
V-253340	WN11-AU-000515	medium	Manual	Windows 11 permissions for the Application event log must prevent access by non-privileged accounts.	Event log configuration check.
V-253341	WN11-AU-000520	medium	Manual	Windows 11 permissions for the Security event log must prevent access by non-privileged accounts.	Event log configuration check.
V-253342	WN11-AU-000525	medium	Manual	Windows 11 permissions for the System event log must prevent access by non-privileged accounts.	Event log configuration check.
V-253351	WN11-CC-000007	medium	Manual	Windows 11 must cover or disable the built-in or attached camera when not in use.	Requires manual verification.
V-253359	WN11-CC-000039	medium	Manual	Run as different user must be removed from context menus.	Requires manual verification.
V-253362	WN11-CC-000050	medium	Manual	Hardened UNC Paths must be defined to require mutual authentication and integrity for at least the *\SYSVOL and *\NE	Requires manual verification.
V-253363	WN11-CC-000052	medium	Manual	Windows 11 must be configured to prioritize ECC Curves with longer key lengths first.	Requires manual verification.
V-253423	WN11-CC-000370	medium	Manual	The convenience PIN for Windows 11 must be disabled.	Requires manual verification.
V-253424	WN11-CC-000385	medium	Manual	Windows Ink Workspace must be configured to disallow access above the lock.	Requires manual verification.
V-253425	WN11-CC-000390	low	Manual	Windows 11 must be configured to prevent users from receiving suggestions for third-party or additional applications.	Requires manual verification.
V-253427	WN11-PK-000005	medium	Manual	The DoD Root CA certificates must be installed in the Trusted Root Store.	Certificate store check - requires manual verification.

V-253428	WN11-PK-000010	medium	**Manual**	The External Root CA certificates must be installed in the Trusted Root Store on unclassified systems.	Certificate store check - requires manual verification.
V-253429	WN11-PK-000015	medium	**Manual**	The DoD Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unclassifie	Certificate store check - requires manual verification.
V-253430	WN11-PK-000020	medium	**Manual**	The US DOD CCEB Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unc	Certificate store check - requires manual verification.
V-253431	WN11-RG-000005	medium	**Manual**	Default permissions for the HKEY_LOCAL_MACHINE registry hive must be maintained.	Requires manual verification.
V-253433	WN11-SO-000010	medium	**Manual**	The built-in guest account must be disabled.	Requires manual verification.
V-253435	WN11-SO-000020	medium	**Manual**	The built-in administrator account must be renamed.	Requires manual verification.
V-253436	WN11-SO-000025	medium	**Manual**	The built-in guest account must be renamed.	Requires manual verification.
V-253445	WN11-SO-000075	medium	**Manual**	The required legal notice must be configured to display before console logon.	Requires manual verification.
V-253446	WN11-SO-000080	low	**Manual**	The Windows message title for the legal notice must be configured.	Requires manual verification.
V-253452	WN11-SO-000140	high	**Manual**	Anonymous SID/Name translation must not be allowed.	Requires manual verification.
V-253457	WN11-SO-000167	medium	**Manual**	Remote calls to the Security Account Manager (SAM) must be restricted to Administrators.	Requires manual verification.
V-253470	WN11-SO-000251	medium	**Manual**	Windows 11 must use multifactor authentication for local and network access to privileged and nonprivileged accounts.	Requires manual verification.

V-253476	WN11-SO-000280	medium	**Manual**	Passwords for enabled local Administrator accounts must be changed at least every 60 days.	Requires manual verification.
V-253477	WN11-UC-000015	low	**Manual**	Toast notifications to the lock screen must be turned off.	Requires manual verification.
V-253478	WN11-UC-000020	medium	**Manual**	Zone information must be preserved when saving attachments.	Requires manual verification.
V-253479	WN11-UR-000005	medium	**Manual**	The "Access Credential Manager as a trusted caller" user right must not be assigned to any groups or accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253480	WN11-UR-000010	medium	**Manual**	The "Access this computer from the network" user right must only be assigned to the Administrators and Remote Desktop Users groups.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253481	WN11-UR-000015	high	**Manual**	The "Act as part of the operating system" user right must not be assigned to any groups or accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253482	WN11-UR-000025	medium	**Manual**	The "Allow log on locally" user right must only be assigned to the Administrators and Users groups.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253483	WN11-UR-000030	medium	**Manual**	The "Back up files and directories" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253484	WN11-UR-000035	medium	**Manual**	The "Change the system time" user right must only be assigned to Administrators and Local Service.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253485	WN11-UR-000040	medium	**Manual**	The "Create a pagefile" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253486	WN11-UR-000045	high	**Manual**	The "Create a token object" user right must not be assigned to any groups or accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253487	WN11-UR-000050	medium	**Manual**	The "Create global objects" user right must only be assigned to Administrators,	User Rights Assignment check - requires manual review of Local Security Policy.

				Service, Local Service, and Network Service.	
V-253488	WN11-UR-000055	medium	**Manual**	The "Create permanent shared objects" user right must not be assigned to any groups or accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253489	WN11-UR-000060	medium	**Manual**	The "Create symbolic links" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253490	WN11-UR-000065	high	**Manual**	The "Debug programs" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253491	WN11-UR-000070	medium	**Manual**	The "Deny access to this computer from the network" user right on workstations must be configured to prevent access from highly privileged domain accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253492	WN11-UR-000075	medium	**Manual**	The "Deny log on as a batch job" user right on domain-joined workstations must be configured to prevent access from highly privileged domain accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253493	WN11-UR-000080	medium	**Manual**	The "Deny log on as a service" user right on Windows 11 domain-joined workstations must be configured to prevent access from highly privileged domain accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253494	WN11-UR-000085	medium	**Manual**	The "Deny log on locally" user right on workstations must be configured to prevent access from highly privileged domain accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253495	WN11-UR-000090	medium	**Manual**	The "Deny log on through Remote Desktop Services" user right on Windows 11 workstations must be configured to prevent access from highly privileged domain accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253496	WN11-UR-000095	medium	**Manual**	The "Enable computer and user accounts to be trusted for delegation" user right must not be assigned to any groups or accounts.	User Rights Assignment check - requires manual review of Local Security Policy.

V-253497	WN11-UR-000100	medium	**Manual**	The "Force shutdown from a remote system" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253498	WN11-UR-000110	medium	**Manual**	The "Impersonate a client after authentication" user right must only be assigned to Administrators, Service, Local Service, and Network Service.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253499	WN11-UR-000120	medium	**Manual**	The "Load and unload device drivers" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253500	WN11-UR-000125	medium	**Manual**	The "Lock pages in memory" user right must not be assigned to any groups or accounts.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253501	WN11-UR-000130	medium	**Manual**	The "Manage auditing and security log" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253502	WN11-UR-000140	medium	**Manual**	The "Modify firmware environment values" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253503	WN11-UR-000145	medium	**Manual**	The "Perform volume maintenance tasks" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253504	WN11-UR-000150	medium	**Manual**	The "Profile single process" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253505	WN11-UR-000160	medium	**Manual**	The "Restore files and directories" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-253506	WN11-UR-000165	medium	**Manual**	The "Take ownership of files or other objects" user right must only be assigned to the Administrators group.	User Rights Assignment check - requires manual review of Local Security Policy.
V-256893	WN11-CC-000391	medium	**Manual**	Internet Explorer must be disabled for Windows 11.	Requires manual verification.
V-257592	WN11-00-000395	medium	**Manual**	Windows 11 must not have portproxy enabled or in use.	Requires manual verification.

V-257770	WN11-AU-000585	medium	**Manual**	Windows 11 must have command line process auditing events enabled for failures.	Requires manual verification.
V-268317	WN11-00-000125	medium	**Manual**	Copilot must be disabled for Windows 11.	Requires manual verification.
V-268318	WN11-CC-000063	medium	**Manual**	Windows 11 systems must use either Group Policy or an approved Mobile Device Management (MDM) product to enforce STIG co	Requires manual verification.
V-278926	WN11-AU-000581	medium	**Manual**	Windows 11 must be configured to audit file system failures.	Requires manual verification.
V-278927	WN11-AU-000582	medium	**Manual**	Windows 11 must be configured to audit file system successes.	Requires manual verification.
V-278928	WN11-AU-000583	medium	**Manual**	Windows 11 must be configured to audit handle manipulation failures.	Requires manual verification.
V-278929	WN11-AU-000584	medium	**Manual**	Windows 11 must be configured to audit handle manipulation successes.	Requires manual verification.
V-278930	WN11-AU-000589	medium	**Manual**	Windows 11 must be configured to audit registry failures.	Requires manual verification.
V-278931	WN11-AU-000586	medium	**Manual**	Windows 11 must be configured to audit registry successes.	Requires manual verification.
V-278932	WN11-AU-000587	medium	**Manual**	Windows 11 must be configured to audit sensitive privilege use successes.	Requires manual verification.
V-278933	WN11-AU-000588	medium	**Manual**	Windows 11 must be configured to audit sensitive privilege use failures.	Requires manual verification.
V-241989	WNFWA-000001	medium	**N/A**	Windows Defender Firewall with Advanced Security must be enabled when connected to a domain.	System is not domain-joined; Domain Profile requirement is N/A.
V-241992	WNFWA-000004	high	**N/A**	Windows Defender Firewall with Advanced Security must block unsolicited inbound connections when connected to a domain.	System is not domain-joined; Domain Profile requirement is N/A.
V-241993	WNFWA-000005	medium	**N/A**	Windows Defender Firewall with Advanced Security must allow outbound	System is not domain-joined; Domain Profile requirement is N/A.

				connections, unless a rule explicitly blocks the connection when connected to a domain.	
V-241994	WNFWA-000009	low	**N/A**	Windows Defender Firewall with Advanced Security log size must be configured for domain connections.	System is not domain-joined; Domain Profile requirement is N/A.
V-241995	WNFWA-000010	low	**N/A**	Windows Defender Firewall with Advanced Security must log dropped packets when connected to a domain.	System is not domain-joined; Domain Profile requirement is N/A.
V-241996	WNFWA-000011	low	**N/A**	Windows Defender Firewall with Advanced Security must log successful connections when connected to a domain.	System is not domain-joined; Domain Profile requirement is N/A.
V-241990	WNFWA-000002	medium	**Pass**	Windows Defender Firewall with Advanced Security must be enabled when connected to a private network.	EnableFirewall=1 (Local) (Expected: == 1)
V-241997	WNFWA-000012	high	**Pass**	Windows Defender Firewall with Advanced Security must block unsolicited inbound connections when connected to a private network.	DefaultInboundAction=1 (Policy) (Expected: == 1)
V-241998	WNFWA-000013	medium	**Pass**	Windows Defender Firewall with Advanced Security must allow outbound connections, unless a rule explicitly blocks the connection when connected to a private network.	DefaultOutboundAction=0 (Policy) (Expected: == 0)
V-241999	WNFWA-000017	low	**Pass**	Windows Defender Firewall with Advanced Security log size must be configured for private network connections.	LogFileSize=16384 (Policy) (Expected: >= 16384)
V-242000	WNFWA-000018	low	**Pass**	Windows Defender Firewall with Advanced Security must log dropped packets when connected to a private network.	LogDroppedPackets=1 (Policy) (Expected: == 1)
V-242001	WNFWA-000019	low	**Pass**	Windows Defender Firewall with Advanced Security must log successful connections when connected to a private network.	LogSuccessfulConnections=1 (Policy) (Expected: == 1)

V-241991	WNFWA-000003	medium	**Pass**	Windows Defender Firewall with Advanced Security must be enabled when connected to a public network.	EnableFirewall=1 (Local) (Expected: == 1)
V-242002	WNFWA-000020	high	**Pass**	Windows Defender Firewall with Advanced Security must block unsolicited inbound connections when connected to a public network.	DefaultInboundAction=1 (Policy) (Expected: == 1)
V-242003	WNFWA-000021	medium	**Pass**	Windows Defender Firewall with Advanced Security must allow outbound connections, unless a rule explicitly blocks the connection when connected to a public network.	DefaultOutboundAction=0 (Policy) (Expected: == 0)
V-242006	WNFWA-000027	low	**Pass**	Windows Defender Firewall with Advanced Security log size must be configured for public network connections.	LogFileSize=16384 (Policy) (Expected: >= 16384)
V-242007	WNFWA-000028	low	**Pass**	Windows Defender Firewall with Advanced Security must log dropped packets when connected to a public network.	LogDroppedPackets=1 (Policy) (Expected: == 1)
V-242008	WNFWA-000029	low	**Pass**	Windows Defender Firewall with Advanced Security must log successful connections when connected to a public network.	LogSuccessfulConnections=1 (Policy) (Expected: == 1)
V-242004	WNFWA-000024	medium	**N/A**	Windows Defender Firewall with Advanced Security local firewall rules must not be merged with Group Policy settings when connected to a public network.	System is not domain-joined.
V-242005	WNFWA-000025	medium	**N/A**	Windows Defender Firewall with Advanced Security local connection rules must not be merged with Group Policy settings when connected to a public network.	System is not domain-joined.
V-242009	WNFWA-000100	medium	**N/A**	Inbound exceptions to the firewall on domain workstations must only allow authorized remote management hosts.	System is not a domain workstation.

V-69239	SV-222387	medium	Manual	App must limit logon sessions per user	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69241	SV-222388	medium	Manual	App must clear temp storage and cookies on session termination	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69243	SV-222389	medium	Manual	App must auto-terminate non-privileged sessions after 15 min idle	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69245	SV-222390	medium	Manual	App must auto-terminate admin sessions after 10 min idle	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69247	SV-222391	medium	Manual	App must provide logoff capability for user sessions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69251	SV-222393	medium	Manual	App must associate security attributes with info in storage	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69253	SV-222394	medium	Manual	App must associate security attributes with info in process	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69255	SV-222395	medium	Manual	App must associate security attributes with info in transmission	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69257	SV-222396	medium	Manual	App must use DoD-approved encryption for remote access sessions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69259	SV-222397	medium	Manual	App must use crypto to protect integrity of remote sessions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69261	SV-222398	medium	Manual	SOAP messages must include signed Message ID, Request, Timestamp, SAML Assertion	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69279	SV-222399	high	Manual	WS_Security messages must use timestamps with creation and expiration	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69281	SV-222400	high	Manual	Validity periods must be verified on WS-Security/SAML messages	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69283	SV-222401	medium	Manual	Each SAML asserting party must provide unique assertion IDs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69285	SV-222402	medium	Manual	Encrypted assertions required when passing through intermediary	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69287	SV-222403	high	**Manual**	SAML SubjectConfirmation must use NotOnOrAfter condition	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69289	SV-222404	high	**Manual**	SAML Conditions must use NotBefore/NotOnOrAfter or OneTimeUse	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69291	SV-222405	medium	**Manual**	Only one OneTimeUse element in SAML Conditions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69293	SV-222406	medium	**Manual**	Encrypt messages when SessionIndex tied to privacy data	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69295	SV-222407	medium	**Manual**	App must provide automated account management mechanisms	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69297	SV-222408	medium	**Manual**	Shared/group account credentials must be terminated when members leave	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69299	SV-222409	medium	**Manual**	Temp user accounts must be auto-removed/disabled within 72 hours	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69303	SV-222412	medium	**Manual**	Unnecessary application accounts must be disabled or deleted	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69305	SV-222413	medium	**Manual**	App must automatically audit account creation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69307	SV-222414	medium	**Manual**	App must automatically audit account modification	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69309	SV-222415	medium	**Manual**	App must automatically audit account disabling actions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69311	SV-222416	medium	**Manual**	App must automatically audit account removal actions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69321	SV-222421	medium	**Manual**	App must automatically audit account enabling actions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69325	SV-222423	medium	**Manual**	Application data protection requirements must be documented	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69327	SV-222424	medium	**Manual**	App must detect data mining attempts on defined data objects	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69329	SV-222425	high	**Manual**	App must enforce approved authorizations for logical access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69331	SV-222426	medium	**Manual**	App must enforce DAC policies over defined subjects and objects	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69333	SV-222427	medium	**Manual**	App must enforce info flow control within the system	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69335	SV-222428	medium	**Manual**	App must enforce info flow control between interconnected systems	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69337	SV-222429	medium	**Manual**	App must prevent non-privileged users from executing privileged functions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69339	SV-222430	high	**Manual**	App must execute without excessive account permissions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69341	SV-222431	medium	**Manual**	App must audit execution of privileged functions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69343	SV-222432	high	**Manual**	App must enforce 3 consecutive invalid logon limit in 15 minutes	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69347	SV-222433	medium	**Manual**	Admin must follow approved process to unlock locked accounts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69357	SV-222438	medium	**Manual**	App must protect against false denial via non-repudiation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69359	SV-222439	medium	**Manual**	Audit aggregation must be time-correlated across components	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69363	SV-222441	medium	**Manual**	App must audit session ID creation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69365	SV-222442	medium	**Manual**	App must audit session ID destruction	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69367	SV-222443	medium	**Manual**	App must audit session ID renewal	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69369	SV-222444	medium	**Manual**	App must not write sensitive data into logs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69371	SV-222445	medium	**Manual**	App must audit session timeouts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69373	SV-222446	medium	**Manual**	App must record timestamp for each audit event	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69375	SV-222447	medium	**Manual**	App must audit HTTP headers (User-Agent, Referer, GET, POST)	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69377	SV-222448	medium	**Manual**	App must audit connecting system IP addresses	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69379	SV-222449	medium	**Manual**	App must record username/user ID with each event	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69381	SV-222450	medium	**Manual**	App must audit successful/unsuccessful privilege grant attempts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69383	SV-222451	medium	**Manual**	App must audit successful/unsuccessful security object access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69385	SV-222452	medium	**Manual**	App must audit successful/unsuccessful security level access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69387	SV-222453	medium	**Manual**	App must audit successful/unsuccessful access to info categories	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69389	SV-222454	medium	**Manual**	App must audit successful/unsuccessful privilege modifications	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69391	SV-222455	medium	**Manual**	App must audit successful/unsuccessful security object modifications	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69393	SV-222456	medium	**Manual**	App must audit successful/unsuccessful security level modifications	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69395	SV-222457	medium	**Manual**	App must audit successful/unsuccessful info category modifications	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69397	SV-222458	medium	**Manual**	App must audit successful/unsuccessful privilege deletions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69399	SV-222459	medium	**Manual**	App must audit successful/unsuccessful security level deletions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69401	SV-222460	medium	**Manual**	App must audit successful/unsuccessful DB security object deletions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69403	SV-222461	medium	**Manual**	App must audit successful/unsuccessful info category deletions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69405	SV-222462	medium	**Manual**	App must audit successful/unsuccessful logon attempts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69407	SV-222463	medium	**Manual**	App must audit privileged activities and system-level access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69409	SV-222464	medium	**Manual**	App must audit start and end time of user sessions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69411	SV-222465	medium	**Manual**	App must audit successful/unsuccessful object access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69413	SV-222466	medium	**Manual**	App must audit all direct access to the information system	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69415	SV-222467	medium	**Manual**	App must audit all account creation, modification, disabling, termination	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69419	SV-222468	medium	**Manual**	App must initiate session auditing upon startup	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69421	SV-222469	medium	**Manual**	App must log shutdown events	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69423	SV-222470	medium	**Manual**	App must log destination IP addresses	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69425	SV-222471	medium	**Manual**	App must log user actions involving data access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69427	SV-222472	medium	**Manual**	App must log user actions involving data changes	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69429	SV-222473	medium	**Manual**	Audit records must include date and time of events	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69431	SV-222474	medium	**Manual**	Audit records must identify which component triggered the event	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69433	SV-222475	medium	**Manual**	Centralized logging must include unique app identifier	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69435	SV-222476	medium	**Manual**	Audit records must contain event outcome	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69437	SV-222477	medium	**Manual**	Audit records must identify individual or process for each event	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69439	SV-222478	medium	**Manual**	Audit must include full-text of privileged commands or group user IDs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69441	SV-222479	medium	**Manual**	Transaction-based apps must implement recovery logs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69443	SV-222480	medium	**Manual**	App must provide centralized audit content management	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69445	SV-222481	medium	**Manual**	App must off-load audit records to different system	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69447	SV-222482	medium	**Manual**	App must write logs to centralized repository	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69449	SV-222483	medium	**Manual**	App must warn SA/ISSO at 75% audit storage capacity	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69451	SV-222484	medium	**Manual**	Moderate/high impact apps must provide real-time audit failure alerts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69453	SV-222485	medium	**Manual**	App must alert ISSO/SA on audit processing failure	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69455	SV-222486	medium	**Manual**	App must shut down on audit failure unless availability overrides	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69457	SV-222487	medium	**Manual**	App must provide centralized audit review from all components	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69459	SV-222488	medium	**Manual**	App must filter audit records by events of interest	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69461	SV-222489	medium	**Manual**	App must support on-demand audit reporting	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69463	SV-222490	medium	**Manual**	App must support on-demand audit review and analysis	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69465	SV-222491	medium	**Manual**	App must support after-the-fact incident investigation via audit	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69467	SV-222492	medium	**Manual**	App must provide on-demand report generation for audit review	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69469	SV-222493	medium	**Manual**	App must provide on-demand reporting capability	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69471	SV-222494	medium	**Manual**	App must provide after-the-fact report generation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69473	SV-222495	medium	**Manual**	Audit reduction must not alter original content or time ordering	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69475	SV-222496	medium	**Manual**	Report generation must not alter original audit content	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69477	SV-222497	medium	**Manual**	App must use system clocks for audit timestamps	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69479	SV-222498	medium	**Manual**	Audit timestamps must map to UTC or GMT	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69481	SV-222499	medium	**Manual**	Audit timestamps must have 1-second minimum granularity	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69483	SV-222500	medium	**Manual**	Audit info must be protected from unauthorized read access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69485	SV-222501	medium	**Manual**	Audit info must be protected from unauthorized modification	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69487	SV-222502	medium	**Manual**	Audit info must be protected from unauthorized deletion	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69489	SV-222503	medium	**Manual**	Audit tools must be protected from unauthorized access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69491	SV-222504	medium	**Manual**	Audit tools must be protected from unauthorized modification	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69493	SV-222505	medium	**Manual**	Audit tools must be protected from unauthorized deletion	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69495	SV-222506	medium	**Manual**	Audit records must be backed up at least every 7 days	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69497	SV-222507	medium	**Manual**	App must use crypto to protect audit integrity	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69499	SV-222508	medium	**Manual**	Audit tools must be cryptographically hashed	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69501	SV-222509	medium	**Manual**	Audit tool integrity must be validated by checking hash values	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69503	SV-222510	medium	**Manual**	App must prohibit user software installation without privilege	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69505	SV-222511	medium	**Manual**	App must enforce config change access restrictions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69507	SV-222512	medium	**Manual**	App must audit who makes configuration changes	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69509	SV-222513	medium	**Manual**	App must prevent unsigned patch/component installation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69511	SV-222514	medium	**Manual**	App must limit privileges to change software libraries	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69513	SV-222515	medium	**Manual**	Application vulnerability assessment must be conducted	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69515	SV-222516	medium	**Manual**	App must restrict execution per org policies	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69517	SV-222517	medium	**Manual**	App must use deny-all permit-by-exception whitelist	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69519	SV-222518	medium	**Manual**	App must disable non-essential capabilities	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69521	SV-222519	medium	**Manual**	App must use only PPSM CAL approved ports and protocols	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69523	SV-222520	medium	**Manual**	App must require reauthentication on privilege/role change	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69525	SV-222521	medium	**Manual**	App must require devices to reauthenticate periodically	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69527	SV-222522	high	**Manual**	App must uniquely identify and authenticate organizational users	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69529	SV-222523	medium	**Manual**	App must use MFA (Alt. Token) for network access to privileged accounts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69531	SV-222524	medium	**Manual**	App must accept PIV credentials	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69533	SV-222525	medium	**Manual**	App must electronically verify PIV credentials	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69535	SV-222526	medium	**Manual**	App must use MFA for network access to non-privileged accounts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69537	SV-222527	medium	**Manual**	App must use MFA (Alt. Token) for local access to privileged accounts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69539	SV-222528	medium	**Manual**	App must use MFA for local access to non-privileged accounts	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69541	SV-222529	medium	**Manual**	Users must authenticate individually before using group authenticator	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69543	SV-222530	medium	**Manual**	App must use replay-resistant auth for privileged network access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69545	SV-222531	medium	**Manual**	App must use replay-resistant auth for non-privileged network access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69547	SV-222532	medium	**Manual**	App must use mutual authentication when required by policy/data owner	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69549	SV-222533	medium	**Manual**	App must authenticate all network connected endpoint devices	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69551	SV-222534	medium	**Manual**	SOA handling non-releasable data must use mutual SSL/TLS	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-69553	SV-222535	medium	**Manual**	Disable device identifiers after 35 days inactivity	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69555	SV-222536	high	**Manual**	App must enforce minimum 15-character password length	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69557	SV-222537	medium	**Manual**	App must require at least one uppercase character in password	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69559	SV-222538	medium	**Manual**	App must require at least one lowercase character in password	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69561	SV-222539	medium	**Manual**	App must require at least one numeric character in password	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69563	SV-222540	medium	**Manual**	App must require at least one special character in password	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69565	SV-222541	medium	**Manual**	App must require change of at least 8 characters on password change	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69567	SV-222542	high	**Manual**	App must only store cryptographic representations of passwords	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69569	SV-222543	high	**Manual**	App must transmit only cryptographically-protected passwords	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69571	SV-222544	medium	**Manual**	App must enforce 24-hour minimum password lifetime	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69573	SV-222545	medium	**Manual**	App must enforce 60-day maximum password lifetime	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69575	SV-222546	medium	**Manual**	App must prohibit password reuse for 5 generations minimum	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-69577	SV-222547	medium	**Manual**	App must allow temp password with immediate change on first use	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70145	SV-222548	medium	**Manual**	Password changeable only by owner or admin	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70147	SV-222549	medium	**Manual**	App must terminate sessions upon account deletion	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-70149	SV-222550	high	**Manual**	PKI auth must validate cert path to accepted trust anchor	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70151	SV-222551	high	**Manual**	PKI auth must enforce authorized private key access	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70153	SV-222552	medium	**Manual**	PKI auth must map identity to individual user or group	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70155	SV-222553	medium	**Manual**	PKI auth must implement local CRL cache	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70157	SV-222554	high	**Manual**	App must not display passwords/PINs as clear text	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70159	SV-222555	high	**Manual**	App must use FIPS-validated crypto modules for authentication	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70161	SV-222556	medium	**Manual**	App must uniquely identify/authenticate non-organizational users	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70163	SV-222557	medium	**Manual**	App must accept PIV from other federal agencies	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70165	SV-222558	medium	**Manual**	App must electronically verify PIV from other federal agencies	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70167	SV-222559	medium	**Manual**	App must accept FICAM-approved third-party credentials	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70169	SV-222560	medium	**Manual**	App must conform to FICAM-issued profiles (SAML/OpenID)	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70171	SV-222561	medium	**Manual**	Non-local maintenance sessions must be audited	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70175	SV-222562	medium	**Manual**	Non-local maintenance must use crypto for integrity	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70177	SV-222563	medium	**Manual**	Non-local maintenance must use crypto for confidentiality	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70179	SV-222564	medium	**Manual**	Non-local maintenance must verify remote disconnection	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-70181	SV-222565	medium	**Manual**	Non-local maintenance must use strong authenticators (CAC)	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70183	SV-222566	medium	**Manual**	App must terminate sessions when non-local maintenance completes	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70185	SV-222567	medium	**Manual**	App must not be vulnerable to race conditions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70187	SV-222568	medium	**Manual**	App must terminate network connections at end of session	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70191	SV-222570	medium	**Manual**	App must use FIPS-validated crypto for signing components	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70193	SV-222571	medium	**Manual**	App must use FIPS-validated crypto for hashing	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70195	SV-222572	medium	**Manual**	App must use FIPS-validated crypto for unclassified data protection	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70197	SV-222573	medium	**Manual**	SAML assertions must use FIPS-approved random numbers for SessionIndex	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70199	SV-222574	medium	**Manual**	User interface must be separated from data/management interfaces	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70201	SV-222575	medium	**Manual**	App must set HTTPOnly flag on session cookies	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70203	SV-222576	medium	**Manual**	App must set Secure flag on session cookies	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70205	SV-222577	high	**Manual**	App must not expose session IDs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70207	SV-222578	high	**Manual**	App must destroy session ID/cookie on logoff or browser close	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70209	SV-222579	medium	**Manual**	App must use system-generated session IDs protecting against fixation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70211	SV-222580	medium	**Manual**	App must validate session identifiers	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-70213	SV-222581	medium	Manual	App must not use URL-embedded session IDs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70215	SV-222582	medium	Manual	App must not re-use or recycle session IDs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70217	SV-222583	medium	Manual	App must use FIPS 140-2/3 random number generator for session IDs	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70219	SV-222584	medium	Manual	App must only use DoD-approved CAs for protected sessions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70221	SV-222585	high	Manual	App must fail to secure state on init/shutdown/abort failure	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70223	SV-222586	medium	Manual	App must preserve failure info for root cause and recovery	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70225	SV-222587	medium	Manual	App must protect confidentiality and integrity of stored info	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70227	SV-222588	high	Manual	App must use approved crypto to prevent unauthorized modification at rest	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70229	SV-222589	high	Manual	App must use appropriate crypto for stored DoD information	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70231	SV-222590	medium	Manual	App must isolate security functions from non-security functions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70233	SV-222591	medium	Manual	App must maintain separate execution domain per process	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70235	SV-222592	medium	Manual	App must prevent unauthorized info transfer via shared resources	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70237	SV-222593	medium	Manual	XML apps must mitigate DoS using filters, parser options, or gateways	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70239	SV-222594	medium	Manual	App must restrict DoS attack capability against itself and others	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70241	SV-222595	medium	Manual	HA web service design must include redundancy mechanisms	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-70245	SV-222596	high	**Manual**	App must protect confidentiality and integrity of transmitted info	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70247	SV-222597	medium	**Manual**	App must use crypto to prevent unauthorized disclosure in transmission	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70249	SV-222598	medium	**Manual**	App must protect confidentiality/integrity during prep for transmission	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70251	SV-222599	medium	**Manual**	App must protect confidentiality/integrity during reception	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70253	SV-222600	medium	**Manual**	App must not disclose unnecessary information to users	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70255	SV-222601	high	**Manual**	App must not store sensitive information in hidden fields	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70257	SV-222602	high	**Manual**	App must protect from Cross-Site Scripting (XSS)	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70259	SV-222603	medium	**Manual**	App must protect from Cross-Site Request Forgery (CSRF)	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70261	SV-222604	high	**Manual**	App must protect from command injection	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70263	SV-222605	medium	**Manual**	App must protect from canonical representation vulnerabilities	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70265	SV-222606	medium	**Manual**	App must validate all input	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70267	SV-222607	high	**Manual**	App must not be vulnerable to SQL Injection	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70269	SV-222608	high	**Manual**	App must not be vulnerable to XML-oriented attacks	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70271	SV-222609	high	**Manual**	App must not be subject to input handling vulnerabilities	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70273	SV-222610	medium	**Manual**	Error messages must not reveal exploitable info to non-privileged users	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-70275	SV-222611	medium	**Manual**	Detailed error messages only for ISSO/ISSM/SA	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70277	SV-222612	high	**Manual**	App must not be vulnerable to overflow attacks	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70279	SV-222613	medium	**Manual**	App must remove old components after updates	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70281	SV-222614	medium	**Manual**	Security updates and patches must be kept up to date	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70283	SV-222615	medium	**Manual**	App must verify correct operation of security functions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70285	SV-222616	medium	**Manual**	Security function verification on startup/restart/command/30 days	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70289	SV-222618	medium	**Manual**	Unsigned Category 1A mobile code must not be used	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70291	SV-222619	medium	**Manual**	Account management process must be implemented and verified	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70293	SV-222620	high	**Manual**	Tiered app web servers must be on separate network segment in DMZ	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70295	SV-222621	medium	**Manual**	Audit trails retained 30 months (non-SAMI) or 5 years (SAMI)	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70297	SV-222622	medium	**Manual**	Audit trails must be reviewed periodically per documentation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70301	SV-222623	medium	**Manual**	Suspected IA policy violations must be reported per DoD procedures	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70303	SV-222624	medium	**Manual**	Active vulnerability testing must be performed	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70307	SV-222625	medium	**Manual**	Execution flow diagrams must address deadlock/recursion in web services	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70309	SV-222626	medium	**Manual**	Config/control files must not be in same directory as user	ASD STIG V6R4: Application-level check requiring manual review of application configuration and

				data	documentation.
V-70311	SV-222627	medium	Manual	Use third-party guidance if no DoD STIG/NSA guide available	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70313	SV-222628	medium	Manual	Ports/protocols must be submitted through DoD PPSM	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70317	SV-222629	medium	Manual	App must be registered with DoD Ports and Protocols Database	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70339	SV-222630	medium	Manual	CM repository must be patched and STIG compliant	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70341	SV-222631	medium	Manual	CM repository access privileges reviewed every 3 months	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70343	SV-222632	medium	Manual	SCM plan must describe config control and change management	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70345	SV-222633	medium	Manual	CCB must meet at least every release cycle	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70347	SV-222634	medium	Manual	App services and interfaces must be IPv6 compatible	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70349	SV-222635	medium	Manual	Critical/HA apps must not be on general purpose machines	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70351	SV-222636	medium	Manual	Contingency plan must exist per DoD policy for availability level	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70353	SV-222637	medium	Manual	Recovery procedures must enable secure and verifiable recovery	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70355	SV-222638	medium	Manual	Data backup at required intervals per DoD policy and risk level	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70357	SV-222639	medium	Manual	Backup copies in fire-rated container or stored offsite	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70359	SV-222640	medium	Manual	Backup/restoration assets must be physically and technically protected	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-70361	SV-222641	medium	**Manual**	App must encrypt key exchange and authenticate endpoints	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70363	SV-222642	high	**Manual**	App must not contain embedded authentication data	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70365	SV-222643	high	**Manual**	App must mark sensitive/classified output when required	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70369	SV-222645	medium	**Manual**	App files must be cryptographically hashed before deployment	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70371	SV-222646	medium	**Manual**	Security tester must be designated for flaw testing	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70375	SV-222648	medium	**Manual**	Application code review must be performed	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70379	SV-222650	medium	**Manual**	Code review flaws must be tracked in defect tracking system	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70381	SV-222651	medium	**Manual**	Changes must be assessed for IA/accreditation impact before implementation	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70383	SV-222652	medium	**Manual**	Security flaws must be addressed in project plan	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70389	SV-222655	medium	**Manual**	Threat models documented and reviewed per release	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70391	SV-222656	medium	**Manual**	App must not have error handling vulnerabilities	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70393	SV-222657	medium	**Manual**	Dev team must provide application incident response plan	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70395	SV-222658	high	**Manual**	All products must be supported by vendor or development team	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70397	SV-222659	high	**Manual**	App must be decommissioned when support is no longer available	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70401	SV-222661	medium	**Manual**	Unnecessary built-in application accounts must be disabled	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

V-70403	SV-222662	high	**Manual**	Default passwords must be changed	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70405	SV-222663	medium	**Manual**	Application Configuration Guide must exist	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70407	SV-222664	medium	**Manual**	Security Classification Guide must exist for classified data apps	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70409	SV-222665	medium	**Manual**	Uncategorized or emerging mobile code must not be used	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70411	SV-222666	medium	**Manual**	Production DB exports must have credentials/sensitive data removed	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70413	SV-222667	medium	**Manual**	DoS attack protections must be implemented per threat model	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70415	SV-222668	medium	**Manual**	System must alert administrator on low resource conditions	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70421	SV-222671	medium	**Manual**	Public-facing apps must route through DMZ	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70425	SV-222673	medium	**Manual**	All program staff must receive annual security training	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.
V-70189	SV-265634	medium	**Manual**	App must use NSA-approved crypto for classified information	ASD STIG V6R4: Application-level check requiring manual review of application configuration and documentation.

Manual Review Steps

V-253258 (WN11-00-000025) - medium - Windows 11 must employ automated mechanisms for flaw remediation (ESS)

1. Contact the site ISSM for ESS software documentation.
2. Verify DOD-approved ESS software is installed, configured, and actively running.
3. Acceptable evidence: CCB-approved Software Baseline or ISSM memo with ESS name/version.

V-253266 (WN11-00-000055) - medium - Alternate operating systems must not be permitted on the same system

1. Run 'bcdedit /enum' in an elevated Command Prompt to list all boot entries.
2. Right-click Start > System > Advanced system settings > Startup and Recovery > Settings.

3. Check 'Default operating system' drop-down. Only Windows 11 should appear.
4. Remove alternate OS entries if present.

V-253269 (WN11-00-000070) - high - Only accounts responsible for administration must have Administrator rights

1. Open Computer Management > Local Users and Groups > Groups > Administrators.
2. Current members: PYTHO-MCWL-001\Administrator, PYTHO-MCWL-001\pytho-mcwl
3. Verify ONLY designated admin accounts/groups are present.
4. Remove any standard user accounts from the group.
5. For domain-joined: Domain Admins should be replaced by a workstation admin group.

V-253282 (WN11-00-000140) - medium - Inbound exceptions to the firewall must only allow authorized remote management hosts

1. Open wf.msc > Inbound Rules.
2. For each Allow rule: double-click > Scope tab.
3. Verify Remote IP address is NOT 'Any IP address'.
4. Set to specific authorized management host IPs/subnets.

V-253290 (WN11-00-000190) - medium - Orphaned SIDs must be removed from user rights

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Double-click each policy and look for unresolved SIDs (*S-1-5-21-...).
3. Verify with domain admin if SID is valid.
4. Remove invalid/orphaned SIDs.

V-253294 (WN11-00-000240) - high - Administrative accounts must not be used with applications that access the internet

1. Verify documented policy prohibiting admin accounts from using browsers/email.
2. Implement AppLocker rules or application removal to enforce technically.
3. Policy must define exceptions for local service administration HTTP(S) tools.

V-253296 (WN11-00-000260) - low - The Windows 11 time service must synchronize with an appropriate DOD time source

1. Run: w32tm /query /configuration
2. Verify NtpServer points to an authorized DOD time source.

V-253340 (WN11-AU-000515) - medium - Windows 11 permissions for the Application event log must prevent access by non-privileged accounts.

Verify the permissions on the Application event log (Application.evtx). Standard user accounts or groups must not have access.

Required permissions: Eventlog - Full Control, SYSTEM - Full Control, Administrators - Full Control.

Default location: %SystemRoot%\SYSTEM32\WINEVT\LOGS\. If permissions do not match, this is a finding.

V-253341 (WN11-AU-000520) - medium - Windows 11 permissions for the Security event log must prevent access by non-privileged accounts.

Verify the permissions on the Security event log (Security.evtx). Standard user accounts or groups must not have access.

Required permissions: Eventlog - Full Control, SYSTEM - Full Control, Administrators - Full Control.

Default location: %SystemRoot%\SYSTEM32\WINEVT\LOGS\. If permissions do not match, this is a finding.

V-253342 (WN11-AU-000525) - medium - Windows 11 permissions for the System event log must prevent access by non-privileged accounts.

Verify the permissions on the System event log (System.evtx). Standard user accounts or groups must not have access.

Required permissions: Eventlog - Full Control, SYSTEM - Full Control, Administrators - Full Control.

Default location: %SystemRoot%\SYSTEM32\WINEVT\LOGS\. If permissions do not match, this is a finding.

V-253351 (WN11-CC-000007) - medium - Windows 11 must cover or disable the built-in or attached camera when not in use.

If the device or operating system does not have a camera installed, this requirement is not applicable.

This requirement is not applicable to mobile devices (smartphones and tablets), where the use of the camera is a local authorizing official (AO) decision.

This requirement is not applicable to dedicated VTC suites located in approved VTC locations that are centrally managed.

For an external c

V-253359 (WN11-CC-000039) - medium - Run as different user must be removed from context menus.

If the following registry values do not exist or are not configured as specified, this is a finding.
The policy configures the same Value Name, Type and Value under four different registry paths.

Registry Hive: HKEY_LOCAL_MACHINE
Registry Paths:
\SOFTWARE\Classes\batfile\shell\runasuser\
\SOFTWARE\Classes\cmdfile\shell\runasuser\
\SOFTWARE\Classes\exefile\shell\runasuser\
\SOFTWARE\Classes\mscfi

V-253362 (WN11-CC-000050) - medium - Hardened UNC Paths must be defined to require mutual authentication and integrity for at least the *\SYSVOL and *\NE

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

If the following registry values do not exist or are not configured as specified, this is a finding.

Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths\

Value Name: *\NETLOGON
Value Type: REG_SZ
Value: RequireMutualAuthentication=1, Requi

V-253363 (WN11-CC-000052) - medium - Windows 11 must be configured to prioritize ECC Curves with longer key lengths first.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002\

Value Name: EccCurves

Value Type: REG_MULTI_SZ
Value: NistP384 NistP256

V-253423 (WN11-CC-000370) - medium - The convenience PIN for Windows 11 must be disabled.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \Software\Policies\Microsoft\Windows\System

Value Name: AllowDomainPINLogon
Value Type: REG_DWORD
Value data: 0

V-253424 (WN11-CC-000385) - medium - Windows Ink Workspace must be configured to disallow access above the lock.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \Software\Policies\Microsoft\WindowsInkWorkspace

Value Name: AllowWindowsInkWorkspace
Value Type: REG_DWORD
Value data: 1

V-253425 (WN11-CC-000390) - low - Windows 11 must be configured to prevent users from receiving suggestions for third-party or additional applications.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_CURRENT_USER
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\CloudContent\

Value Name: DisableThirdPartySuggestions

Type: REG_DWORD
Value: 0x00000001 (1)

V-253427 (WN11-PK-000005) - medium - The DoD Root CA certificates must be installed in the Trusted Root Store.

Verify the DoD Root CA certificates are installed as Trusted Root Certification Authorities.

The certificates and thumbprints referenced below apply to unclassified systems; refer to PKE documentation for other networks.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\root | Where Subject -Like "*DoD*" | FL Subject, Thumbprint, NotAfte

V-253428 (WN11-PK-000010) - medium - The External Root CA certificates must be installed in the Trusted Root Store on unclassified systems.

Verify the ECA Root CA certificates are installed on unclassified systems as Trusted Root Certification Authorities.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\root | Where Subject -Like "*ECA*" | FL Subject, Thumbprint, NotAfter

If the following certificate "Subject" and "Thumbprint" information is not displayed, this is a findin

V-253429 (WN11-PK-000015) - medium - The DoD Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unclassifie

Verify the DoD Interoperability cross-certificates are installed on unclassified systems as Untrusted Certificates.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\disallowed | Where {.Issuer -Like "*DoD Interoperability*" -and .Subject -Like "*DoD*"} | FL Subject, Issuer, Thumbprint, NotAfter

If the following certificate "Subject"

V-253430 (WN11-PK-000020) - medium - The US DOD CCEB Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unc

Verify the US DOD CCEB Interoperability Root CA cross-certificate is installed on unclassified systems as an Untrusted Certificate.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\disallowed | Where Issuer -Like "*CCEB Interoperability*" | FL Subject, Issuer, Thumbprint, NotAfter

If the following certificate "Subject", "Issuer", and "T

V-253431 (WN11-RG-000005) - medium - Default permissions for the HKEY_LOCAL_MACHINE registry hive must be maintained.

Verify the default registry permissions for the keys note below of the HKEY_LOCAL_MACHINE hive.

If any non-privileged groups such as Everyone, Users or Authenticated Users have greater than Read permission, this is a finding.

Run "Regedit".
Right click on the registry areas noted below.
Select "Permissions..." and the "Advanced" button.

HKEY_LOCAL_MACHINE\SECURITY
Type - "Allow" for all
Inherit

V-253433 (WN11-SO-000010) - medium - The built-in guest account must be disabled.

Verify in gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options.

If "Accounts: Guest account status" is not set to "Disabled", this is a finding.

V-253435 (WN11-SO-000020) - medium - The built-in administrator account must be renamed.

Verify in gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options.

If "Accounts: Rename administrator account" is set to "Administrator", this is a finding.

V-253436 (WN11-SO-000025) - medium - The built-in guest account must be renamed.

Verify in gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options.

If "Accounts: Rename guest account" is set to "Guest", this is a finding.

V-253445 (WN11-SO-000075) - medium - The required legal notice must be configured to display before console logon.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: LegalNoticeText

Value Type: REG_SZ
Value:
You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only.

By using this IS (w

V-253446 (WN11-SO-000080) - low - The Windows message title for the legal notice must be configured.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: LegalNoticeCaption

Value Type: REG_SZ
Value: See message title above

"DoD Notice and Consent Banner", "US Department of Defense Warning Statement" or a site-defined equivalen

V-253452 (WN11-SO-000140) - high - Anonymous SID/Name translation must not be allowed.

Verify the effective setting in Local Group Policy Editor.
Run "gpedit.msc".

Navigate to Local Computer Policy >> Computer Configuration >> Windows Settings >> Security Settings >> Local Policies >> Security Options.

If the value for "Network access: Allow anonymous SID/Name translation" is not set to "Disabled", this is a finding.

V-253457 (WN11-SO-000167) - medium - Remote calls to the Security Account Manager (SAM) must be restricted to Administrators.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: RestrictRemoteSAM

Value Type: REG_SZ
Value: O:BAG:BAD:(A;;RC;;;BA)

If a domain application account such as for a management tool requires this user right, this would not be a finding.
Vendor docu

V-253470 (WN11-SO-000251) - medium - Windows 11 must use multifactor authentication for local and network access to privileged and nonprivileged accounts.

If the system is not a member of a domain, this is Not Applicable.

If all of the following settings exist and are populated, this is not a finding.

\HKLM\SOFTWARE\Microsoft\Cryptography\Calais\Readers
\HKLM\SOFTWARE\Microsoft\Cryptography\Calais\SmartCards

V-253476 (WN11-SO-000280) - medium - Passwords for enabled local Administrator accounts must be changed at least every 60 days.

If there are no enabled local Administrator accounts, this is Not Applicable.

Review the password last set date for the enabled local Administrator account.

On the standalone or domain-joined workstation:

Open "PowerShell".

Enter "Get-LocalUser -Name * | Select-Object *".

If the "PasswordLastSet" date is greater than "60" days old for the local Administrator account for administering the comp

V-253477 (WN11-UC-000015) - low - Toast notifications to the lock screen must be turned off.

If the following registry value does not exist or is not configured as specified, this is a finding:

Registry Hive: HKEY_CURRENT_USER
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\CurrentVersion\PushNotifications\

Value Name: NoToastApplicationNotificationOnLockScreen

Value Type: REG_DWORD
Value: 1

V-253478 (WN11-UC-000020) - medium - Zone information must be preserved when saving attachments.

The default behavior is for Windows to mark file attachments with their zone information.

If it exists and is configured with a value of "1", this is a finding.

Registry Hive: HKEY_CURRENT_USER
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Attachments\

Value Name: SaveZoneInformation

Value Type: REG_DWORD
Value: 0x00000002 (2) (or if the Value Name does not exist)

V-253479 (WN11-UR-000005) - medium - The "Access Credential Manager as a trusted caller" user right must not be assigned to any groups or accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Access Credential Manager as a trusted caller" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253480 (WN11-UR-000010) - medium - The "Access this computer from the network" user right must only be assigned to the Administrators and Remote Desktop Users groups.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Access this computer from the network" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253481 (WN11-UR-000015) - high - The "Act as part of the operating system" user right must not be assigned to any groups or accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Act as part of the operating system" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253482 (WN11-UR-000025) - medium - The "Allow log on locally" user right must only be assigned to the Administrators and Users groups.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Allow log on locally" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253483 (WN11-UR-000030) - medium - The "Back up files and directories" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Back up files and directories" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253484 (WN11-UR-000035) - medium - The "Change the system time" user right must only be assigned to Administrators and Local Service.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Change the system time" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253485 (WN11-UR-000040) - medium - The "Create a pagefile" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Create a pagefile" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253486 (WN11-UR-000045) - high - The "Create a token object" user right must not be assigned to any groups or accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Create a token object" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253487 (WN11-UR-000050) - medium - The "Create global objects" user right must only be assigned to Administrators, Service, Local Service, and Network Service.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Create global objects" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253488 (WN11-UR-000055) - medium - The "Create permanent shared objects" user right must not be assigned to any groups or accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Create permanent shared objects" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253489 (WN11-UR-000060) - medium - The "Create symbolic links" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Create symbolic links" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253490 (WN11-UR-000065) - high - The "Debug programs" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Debug programs" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253491 (WN11-UR-000070) - medium - The "Deny access to this computer from the network" user right on workstations must be configured to prevent access from highly privileged domain accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Deny access to this computer from the network" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253492 (WN11-UR-000075) - medium - The "Deny log on as a batch job" user right on domain-joined workstations must be configured to prevent access from highly privileged domain accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Deny log on as a batch job" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253493 (WN11-UR-000080) - medium - The "Deny log on as a service" user right on Windows 11 domain-joined workstations must be configured to prevent access from highly privileged domain accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Deny log on as a service" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253494 (WN11-UR-000085) - medium - The "Deny log on locally" user right on workstations must be configured to prevent access from highly privileged domain accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Deny log on locally" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253495 (WN11-UR-000090) - medium - The "Deny log on through Remote Desktop Services" user right on Windows 11 workstations must be configured to prevent access from highly privileged domain accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Deny log on through Remote Desktop Services" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253496 (WN11-UR-000095) - medium - The "Enable computer and user accounts to be trusted for delegation" user right must not be assigned to any groups or accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Enable computer and user accounts to be trusted for delegation" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253497 (WN11-UR-000100) - medium - The "Force shutdown from a remote system" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Force shutdown from a remote system" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253498 (WN11-UR-000110) - medium - The "Impersonate a client after authentication" user right must only be assigned to Administrators, Service, Local Service, and Network Service.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Impersonate a client after authentication" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253499 (WN11-UR-000120) - medium - The "Load and unload device drivers" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Load and unload device drivers" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253500 (WN11-UR-000125) - medium - The "Lock pages in memory" user right must not be assigned to any groups or accounts.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Lock pages in memory" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253501 (WN11-UR-000130) - medium - The "Manage auditing and security log" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Manage auditing and security log" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253502 (WN11-UR-000140) - medium - The "Modify firmware environment values" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.

2. Verify the policy for "Modify firmware environment values" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253503 (WN11-UR-000145) - medium - The "Perform volume maintenance tasks" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Perform volume maintenance tasks" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253504 (WN11-UR-000150) - medium - The "Profile single process" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Profile single process" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253505 (WN11-UR-000160) - medium - The "Restore files and directories" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Restore files and directories" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-253506 (WN11-UR-000165) - medium - The "Take ownership of files or other objects" user right must only be assigned to the Administrators group.

1. Run gpedit.msc > Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment.
2. Verify the policy for "Take ownership of files or other objects" matches the STIG requirement.
3. Adjust group/account assignments per STIG guidance.

V-256893 (WN11-CC-000391) - medium - Internet Explorer must be disabled for Windows 11.

Determine if IE11 is installed or enabled on Windows 11 semi-annual channel.

If IE11 is installed or not disabled on Windows 11 semi-annual channel, this is a finding.

If IE11 is installed on an unsupported operating system and is enabled or installed, this is a finding.

For more information, visit: https://learn.microsoft.com/en-us/lifecycle/faq/internet-explorer-microsoft-edge#what-is-the-lif

V-257592 (WN11-00-000395) - medium - Windows 11 must not have portproxy enabled or in use.

Check the registry key for existence of proxied ports:
HKLM\SYSTEM\CurrentControlSet\Services\PortProxy\.

If the key contains v4tov4\tcp\ or is populated v4tov4\tcp\, this is a finding.

Run "netsh interface portproxy show all".

If the command displays any results, this is a finding.

V-257770 (WN11-AU-000585) - medium - Windows 11 must have command line process auditing events enabled for failures.

Ensure Audit Process Creation auditing has been enabled:

Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policy >> Detailed Tracking >> Audit Process Creation.

If "Audit Process Creation" is not set to "Failure", this is a finding.

V-268317 (WN11-00-000125) - medium - Copilot must be disabled for Windows 11.

Run the following PowerShell command as an administrator:

Get-AppxPackage -AllUsers | Where-Object { .Name -like "*Copilot*" }

If Microsoft.Copilot displays, this is a finding.

V-268318 (WN11-CC-000063) - medium - Windows 11 systems must use either Group Policy or an approved Mobile Device Management (MDM) product to enforce STIG co

Verify the Windows 11 system is receiving policy from either group Policy or an MDM with the following steps:

From a command line or PowerShell:

gpresult /R
OS Configuration: Member Workstation

If the system is not being managed by GPO, ask the administrator to indicate which MDM is managing the device.

From PowerShell: Get-Service -Name "IntuneManagementExtension"

If the Windows 11 system is

V-278926 (WN11-AU-000581) - medium - Windows 11 must be configured to audit file system failures.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Object Access >> Audit File System.

If "Audit File System" is not set to "Failure", this is a finding.

V-278927 (WN11-AU-000582) - medium - Windows 11 must be configured to audit file system successes.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Object Access >> Audit File System.

If "Audit File System" is not set to "Success", this is a finding.

V-278928 (WN11-AU-000583) - medium - Windows 11 must be configured to audit handle manipulation failures.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Object Access >> Audit Handle Manipulation.

If "Audit Handle Manipulation" is not set to "Failure", this is a finding.

V-278929 (WN11-AU-000584) - medium - Windows 11 must be configured to audit handle manipulation successes.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Object Access >> Audit Handle Manipulation.

If "Audit Handle Manipulation" is not set to "Success", this is a finding.

V-278930 (WN11-AU-000589) - medium - Windows 11 must be configured to audit registry failures.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Object Access >> Audit Registry.

If "Audit Registry" is not set to "Failure", this is a finding.

V-278931 (WN11-AU-000586) - medium - Windows 11 must be configured to audit registry successes.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Object Access >> Audit Registry.

If "Audit Registry" is not set to "Success", this is a finding.

V-278932 (WN11-AU-000587) - medium - Windows 11 must be configured to audit sensitive privilege use successes.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Privilege Use >> Audit Sensitive Privilege Use.

If "Audit Sensitive Privilege Use" is not set to "Success", this is a finding.

V-278933 (WN11-AU-000588) - medium - Windows 11 must be configured to audit sensitive privilege use failures.

Verify auditing is enabled: Computer Configuration >> Windows Settings >> Security Settings >> Advanced Audit Policy Configuration >> System Audit Policies >> Privilege Use >> Audit Sensitive Privilege Use.

If "Audit Sensitive Privilege Use" is not set to "Failure", this is a finding.

V-69239 (SV-222387) - medium - App must limit logon sessions per user

Review app session config. Verify per-user session limit is enforced per organizational policy.

V-69241 (SV-222388) - medium - App must clear temp storage and cookies on session termination

Log in/out of app. Check cookies and local storage for residual auth data after logout. No username/password should remain.

V-69243 (SV-222389) - medium - App must auto-terminate non-privileged sessions after 15 min idle

Log in as non-privileged user. Leave idle 15 min. Verify session terminates automatically.

V-69245 (SV-222390) - medium - App must auto-terminate admin sessions after 10 min idle

Log in as admin user. Leave idle 10 min. Verify session terminates automatically.

V-69247 (SV-222391) - medium - App must provide logoff capability for user sessions

Verify app provides a visible logoff function and session is fully terminated on logoff.

V-69251 (SV-222393) - medium - App must associate security attributes with info in storage

If app processes classified/CUI data, verify data markings are maintained in storage. N/A if no marking requirement.

V-69253 (SV-222394) - medium - App must associate security attributes with info in process

If app processes classified/CUI data, verify data markings retained during processing. N/A if no marking requirement.

V-69255 (SV-222395) - medium - App must associate security attributes with info in transmission

If app processes classified/CUI data, verify data markings retained during transmission. N/A if no marking requirement.

V-69257 (SV-222396) - medium - App must use DoD-approved encryption for remote access sessions

Verify app uses TLS for all remote sessions. Check for padlock icon in browser or TLS config in app settings.

V-69259 (SV-222397) - medium - App must use crypto to protect integrity of remote sessions

Verify app uses TLS to protect integrity of all remote access sessions.

V-69261 (SV-222398) - medium - SOAP messages must include signed Message ID, Request, Timestamp, SAML Assertion

If app uses SOAP, verify messages include digitally signed Message ID, Service Request, Timestamp, SAML Assertion. N/A if no SOAP.

V-69279 (SV-222399) - high - WS_Security messages must use timestamps with creation and expiration

If app uses WS-Security, verify messages contain timestamps, sequence numbers, and expiration. N/A if no WS-Security.

V-69281 (SV-222400) - high - Validity periods must be verified on WS-Security/SAML messages

If app uses WSS/SAML, verify validity periods are checked on all messages. N/A if no WSS/SAML.

V-69283 (SV-222401) - medium - Each SAML asserting party must provide unique assertion IDs

If app uses SAML, verify assertion IDs are unique per asserting party. N/A if no SAML.

V-69285 (SV-222402) - medium - Encrypted assertions required when passing through intermediary

If app uses WS-Security tokens via intermediary, verify approved encryption. N/A if no WS-Security.

V-69287 (SV-222403) - high - SAML SubjectConfirmation must use NotOnOrAfter condition

If app uses SAML, verify SubjectConfirmation contains NotOnOrAfter element. N/A if no SAML.

V-69289 (SV-222404) - high - SAML Conditions must use NotBefore/NotOnOrAfter or OneTimeUse

If app uses SAML, verify Conditions contains NotBefore+NotOnOrAfter or OneTimeUse. N/A if no SAML.

V-69291 (SV-222405) - medium - Only one OneTimeUse element in SAML Conditions

If app uses SAML, verify only one OneTimeUse element exists in Conditions. N/A if no SAML.

V-69293 (SV-222406) - medium - Encrypt messages when SessionIndex tied to privacy data

If app uses SAML AuthnStatement with SessionIndex tied to privacy data, verify encryption. N/A if no SAML.

V-69295 (SV-222407) - medium - App must provide automated account management mechanisms

Verify app uses automated account management (e.g., AD/LDAP integration). Check for automated handling of inactive/terminated accounts.

V-69297 (SV-222408) - medium - Shared/group account credentials must be terminated when members leave

If shared/group accounts exist, verify procedures for credential changes when members depart. N/A if no shared accounts.

V-69299 (SV-222409) - medium - Temp user accounts must be auto-removed/disabled within 72 hours

If temp accounts are allowed, verify auto-disable/removal within 72 hours of creation.

V-69303 (SV-222412) - medium - Unnecessary application accounts must be disabled or deleted

Generate list of all app accounts. Validate each is necessary. Disable/delete unnecessary ones.

V-69305 (SV-222413) - medium - App must automatically audit account creation

Create test account and verify creation event is logged with account name, date/time.

V-69307 (SV-222414) - medium - App must automatically audit account modification

Modify test account and verify modification event is logged with account name, date/time.

V-69309 (SV-222415) - medium - App must automatically audit account disabling actions

Disable test account and verify disabling event is logged with account name, date/time.

V-69311 (SV-222416) - medium - App must automatically audit account removal actions

Remove test account and verify removal event is logged with account name, date/time.

V-69321 (SV-222421) - medium - App must automatically audit account enabling actions

Enable test account and verify enabling event is logged with account name, date/time.

V-69325 (SV-222423) - medium - Application data protection requirements must be documented

Verify documentation exists identifying data elements, protection requirements, and methods used.

V-69327 (SV-222424) - medium - App must detect data mining attempts on defined data objects

If data mining protections are required, verify protections (query limits, alerts, record limits). N/A if not required.

V-69329 (SV-222425) - high - App must enforce approved authorizations for logical access

Verify RBAC or equivalent is enforced. Test with restricted user to confirm denied access to unauthorized resources.

V-69331 (SV-222426) - medium - App must enforce DAC policies over defined subjects and objects

If DAC is implemented, verify user1 can grant access to user2 and user3 is denied. N/A if no DAC.

V-69333 (SV-222427) - medium - App must enforce info flow control within the system

If app provides data flow control, verify labeled data cannot be sent to prohibited areas. N/A if no flow control.

V-69335 (SV-222428) - medium - App must enforce info flow control between interconnected systems

If app provides inter-system flow control, verify labeled data cannot flow to prohibited systems. N/A if no flow control.

V-69337 (SV-222429) - medium - App must prevent non-privileged users from executing privileged functions

Check app process accounts are not in Administrators group (Windows) or UID 0 (UNIX). Verify file permissions.

V-69339 (SV-222430) - high - App must execute without excessive account permissions

Verify app accounts are not admin/DBA. Check OS group membership and database privileges are minimized.

V-69341 (SV-222431) - medium - App must audit execution of privileged functions

Perform admin tasks and verify privileged actions are logged with action detail, date/time.

V-69343 (SV-222432) - high - App must enforce 3 consecutive invalid logon limit in 15 minutes

Attempt 3 incorrect logons within 15 min. Verify account locks on 4th attempt.

V-69347 (SV-222433) - medium - Admin must follow approved process to unlock locked accounts

Verify documented and ISSO/ISSM-approved unlock process exists including identity validation.

V-69357 (SV-222438) - medium - App must protect against false denial via non-repudiation

If non-repudiation (digital signatures) is required by design, verify functionality works. N/A if not required.

V-69359 (SV-222439) - medium - Audit aggregation must be time-correlated across components

If app aggregates logs from multiple systems, verify timestamps correlate. N/A if no log aggregation.

V-69363 (SV-222441) - medium - App must audit session ID creation

Create new session and verify creation event is logged. N/A if delegated to app server.

V-69365 (SV-222442) - medium - App must audit session ID destruction

Terminate session and verify destruction event is logged. N/A if delegated to app server.

V-69367 (SV-222443) - medium - App must audit session ID renewal

Escalate privileges and verify new session info is created and logged. N/A if delegated to app server.

V-69369 (SV-222444) - medium - App must not write sensitive data into logs

Search logs for passwords, SSNs, session IDs, encryption keys, source code. No sensitive data should be present.

V-69371 (SV-222445) - medium - App must audit session timeouts

Let session timeout and verify timeout event is logged. N/A if delegated to app server.

V-69373 (SV-222446) - medium - App must record timestamp for each audit event

Review logs and verify each event has a corresponding date/time stamp.

V-69375 (SV-222447) - medium - App must audit HTTP headers (User-Agent, Referer, GET, POST)

Perform app actions and verify HTTP header info (User-Agent, Referer, etc.) is recorded in logs.

V-69377 (SV-222448) - medium - App must audit connecting system IP addresses

Connect remotely and verify source IP address is recorded in logs.

V-69379 (SV-222449) - medium - App must record username/user ID with each event

Perform app actions and verify user ID is recorded with each log event.

V-69381 (SV-222450) - medium - App must audit successful/unsuccessful privilege grant attempts

Grant privileges (success and failure scenarios) and verify both events are logged with user identity.

V-69383 (SV-222451) - medium - App must audit successful/unsuccessful security object access

Access security objects (success and failure) and verify both events are logged.

V-69385 (SV-222452) - medium - App must audit successful/unsuccessful security level access

Access different security levels (success and failure) and verify both events are logged.

V-69387 (SV-222453) - medium - App must audit successful/unsuccessful access to info categories

Access protected categories (success and failure) and verify both are logged. N/A if no compartmentalized data.

V-69389 (SV-222454) - medium - App must audit successful/unsuccessful privilege modifications

Modify privileges (success and failure) and verify both events are logged with user identity.

V-69391 (SV-222455) - medium - App must audit successful/unsuccessful security object modifications

Modify security objects (success and failure) and verify both events are logged.

V-69393 (SV-222456) - medium - App must audit successful/unsuccessful security level modifications

Modify security levels (success and failure) and verify both events are logged.

V-69395 (SV-222457) - medium - App must audit successful/unsuccessful info category modifications

Modify protected categories (success and failure) and verify both are logged. N/A if no compartmentalized data.

V-69397 (SV-222458) - medium - App must audit successful/unsuccessful privilege deletions

Delete privileges (success and failure) and verify both events are logged.

V-69399 (SV-222459) - medium - App must audit successful/unsuccessful security level deletions

Delete security levels (success and failure) and verify both events are logged.

V-69401 (SV-222460) - medium - App must audit successful/unsuccessful DB security object deletions

Delete database security objects (success and failure) and verify both events are logged.

V-69403 (SV-222461) - medium - App must audit successful/unsuccessful info category deletions

Delete protected categories (success and failure) and verify both are logged. N/A if no compartmentalized data.

V-69405 (SV-222462) - medium - App must audit successful/unsuccessful logon attempts

Log in successfully and unsuccessfully. Verify both events are recorded in logs.

V-69407 (SV-222463) - medium - App must audit privileged activities and system-level access

Perform admin actions (modify logging, start/stop services). Verify privileged activity is logged.

V-69409 (SV-222464) - medium - App must audit start and end time of user sessions

Start and end a session. Verify both start and end timestamps are recorded in logs.

V-69411 (SV-222465) - medium - App must audit successful/unsuccessful object access

Access app objects (files, folders, modules). Verify success and failure events are logged.

V-69413 (SV-222466) - medium - App must audit all direct access to the information system

If app provides direct OS access (commands, file navigation), verify all such access is logged. N/A if no direct access.

V-69415 (SV-222467) - medium - App must audit all account creation, modification, disabling, termination

Perform each account action (create, modify, disable, terminate). Verify all are logged individually.

V-69419 (SV-222468) - medium - App must initiate session auditing upon startup

Start app service and verify logging begins immediately with startup sequence events recorded.

V-69421 (SV-222469) - medium - App must log shutdown events

Shut down app service and verify shutdown event is recorded in logs.

V-69423 (SV-222470) - medium - App must log destination IP addresses

If app initiates remote connections (including DNS/AD/LDAP), verify destination IPs are logged. N/A if no outbound connections.

V-69425 (SV-222471) - medium - App must log user actions involving data access

Access data elements and verify access events are logged with user ID.

V-69427 (SV-222472) - medium - App must log user actions involving data changes

Modify data elements and verify change events are logged with user ID.

V-69429 (SV-222473) - medium - Audit records must include date and time of events

Verify all audit records include date and time for each event.

V-69431 (SV-222474) - medium - Audit records must identify which component triggered the event

Verify logs identify the source component, module, library, or service name for each event.

V-69433 (SV-222475) - medium - Centralized logging must include unique app identifier

If using centralized logging, verify app name and hostname are included in logs. N/A if logging locally.

V-69435 (SV-222476) - medium - Audit records must contain event outcome

Verify logs include outcome (SUCCESS, FAILURE, ERROR) for each operation.

V-69437 (SV-222477) - medium - Audit records must identify individual or process for each event

Verify logs include user ID or process identity for each event.

V-69439 (SV-222478) - medium - Audit must include full-text of privileged commands or group user IDs

Execute privileged commands and verify full text is logged. Verify group account individual users are identified.

V-69441 (SV-222479) - medium - Transaction-based apps must implement recovery logs

If app is transaction-based, verify transaction logging is enabled. N/A if not transaction-based.

V-69443 (SV-222480) - medium - App must provide centralized audit content management

Verify app provides interface to configure what is captured in audit logs across all components. N/A if using enterprise logging.

V-69445 (SV-222481) - medium - App must off-load audit records to different system

Verify automated log transfer to separate system per approved schedule. N/A if using centralized logging.

V-69447 (SV-222482) - medium - App must write logs to centralized repository

Verify app writes logs to centralized log management system expeditiously.

V-69449 (SV-222483) - medium - App must warn SA/ISSO at 75% audit storage capacity

Verify storage capacity alarms are set at 75%. N/A if using centralized logging with its own alerting.

V-69451 (SV-222484) - medium - Moderate/high impact apps must provide real-time audit failure alerts

Verify real-time alerts configured for audit system failures. N/A if using centralized logging.

V-69453 (SV-222485) - medium - App must alert ISSO/SA on audit processing failure

Verify alerts configured for audit processing failures. N/A if using centralized logging.

V-69455 (SV-222486) - medium - App must shut down on audit failure unless availability overrides

Verify app halts on audit failure, or if overridden: verify log overwrite oldest-first or local spooling.

V-69457 (SV-222487) - medium - App must provide centralized audit review from all components

Verify all app logs are reviewable from one central location. N/A if using centralized logging.

V-69459 (SV-222488) - medium - App must filter audit records by events of interest

Verify filtering by: user, event type, date/time, IP, resource, severity, keywords. N/A if using centralized logging.

V-69461 (SV-222489) - medium - App must support on-demand audit reporting

Verify on-demand reports from filtered audit data (screen, soft copy, or print). N/A if using centralized logging.

V-69463 (SV-222490) - medium - App must support on-demand audit review and analysis

Verify on-demand audit review from filtered data. N/A if using centralized logging.

V-69465 (SV-222491) - medium - App must support after-the-fact incident investigation via audit

Verify audit data can be filtered and reviewed for historical investigations. N/A if using centralized logging.

V-69467 (SV-222492) - medium - App must provide on-demand report generation for audit review

Verify immediate ad-hoc audit report generation capability. N/A if using centralized logging.

V-69469 (SV-222493) - medium - App must provide on-demand reporting capability

Verify customizable immediate ad-hoc log reporting. N/A if using centralized logging.

V-69471 (SV-222494) - medium - App must provide after-the-fact report generation

Verify report generation for forensic investigations. N/A if using centralized logging.

V-69473 (SV-222495) - medium - Audit reduction must not alter original content or time ordering

Apply filters, verify original records unchanged. Clear filters and re-verify records intact.

V-69475 (SV-222496) - medium - Report generation must not alter original audit content

Generate reports and verify original log records remain unmodified.

V-69477 (SV-222497) - medium - App must use system clocks for audit timestamps

Compare app log timestamps with OS clock. Verify they correlate.

V-69479 (SV-222498) - medium - Audit timestamps must map to UTC or GMT

Verify app timestamps map to UTC/GMT. N/A if using OS system clock mapped to UTC/GMT.

V-69481 (SV-222499) - medium - Audit timestamps must have 1-second minimum granularity

Compare log timestamps with OS clock over 10 min. Verify within 1 second. N/A if using OS time source.

V-69483 (SV-222500) - medium - Audit info must be protected from unauthorized read access

Verify log file permissions restrict read access to authorized roles only. Test with non-privileged account.

V-69485 (SV-222501) - medium - Audit info must be protected from unauthorized modification

Verify log file permissions restrict write/modify access. Test with non-privileged account.

V-69487 (SV-222502) - medium - Audit info must be protected from unauthorized deletion

Verify log file permissions restrict delete access. Test with non-privileged account.

V-69489 (SV-222503) - medium - Audit tools must be protected from unauthorized access

Verify audit tool file permissions restrict access to authorized users. N/A if no separate audit tools.

V-69491 (SV-222504) - medium - Audit tools must be protected from unauthorized modification

Verify audit tool files have restricted write permissions. N/A if no separate audit tools.

V-69493 (SV-222505) - medium - Audit tools must be protected from unauthorized deletion

Verify audit tool files have restricted delete permissions. N/A if no separate audit tools.

V-69495 (SV-222506) - medium - Audit records must be backed up at least every 7 days

Verify backup settings include audit log backup every 7 days. N/A if no built-in backup capability.

V-69497 (SV-222507) - medium - App must use crypto to protect audit integrity

Verify cryptographic hash/digest is created for stored log files. N/A if using centralized logging with crypto.

V-69499 (SV-222508) - medium - Audit tools must be cryptographically hashed

Verify hash values exist for audit tool files. N/A if no separate audit tools or file monitoring in place.

V-69501 (SV-222509) - medium - Audit tool integrity must be validated by checking hash values

Verify periodic hash validation process for audit tools. N/A if no separate audit tools.

V-69503 (SV-222510) - medium - App must prohibit user software installation without privilege

As regular user, attempt software install. Verify denied unless from approved repository.

V-69505 (SV-222511) - medium - App must enforce config change access restrictions

As non-privileged user, attempt config changes. Verify denied. Check config file permissions.

V-69507 (SV-222512) - medium - App must audit who makes configuration changes

Make config changes as admin and verify user account is logged in audit records.

V-69509 (SV-222513) - medium - App must prevent unsigned patch/component installation

Verify app can prevent unsigned patches or vendor provides hash values for manual pre-install verification.

V-69511 (SV-222514) - medium - App must limit privileges to change software libraries

Check file permissions on app library folders. Verify restricted to authorized users/processes.

V-69513 (SV-222515) - medium - Application vulnerability assessment must be conducted

Obtain latest scan results covering all app components. High-risk issues must be fixed or mitigated.

V-69515 (SV-222516) - medium - App must restrict execution per org policies

Verify execution restrictions via Group Policy, AppLocker, SRP, or RBAC per policy. N/A if no restrictions required.

V-69517 (SV-222517) - medium - App must use deny-all permit-by-exception whitelist

Verify deny-all whitelist via AppLocker, WDAC, or equivalent. N/A if not a config management application.

V-69519 (SV-222518) - medium - App must disable non-essential capabilities

Review app features, modules, and running services. Disable any not required for mission objectives.

V-69521 (SV-222519) - medium - App must use only PPSM CAL approved ports and protocols

Identify app ports/protocols. Verify against PPSM CAL at https://cyber.mil/ppsm/cal/.

V-69523 (SV-222520) - medium - App must require reauthentication on privilege/role change

Change user role within app and verify reauthentication is required before proceeding.

V-69525 (SV-222521) - medium - App must require devices to reauthenticate periodically

Verify device reauthentication interval is configured per local policy requirements.

V-69527 (SV-222522) - high - App must uniquely identify and authenticate organizational users

Verify unique user account and password/CAC are required for access. N/A for publicly releasable data.

V-69529 (SV-222523) - medium - App must use MFA (Alt. Token) for network access to privileged accounts

Verify admin network access requires Alt. Token. CAC alone should not grant admin functions.

V-69531 (SV-222524) - medium - App must accept PIV credentials

Verify app prompts for CAC certificate selection. N/A if not PK-enabled or public data.

V-69533 (SV-222525) - medium - App must electronically verify PIV credentials

Verify app validates CAC and requires PIN entry. N/A if not PK-enabled or public data.

V-69535 (SV-222526) - medium - App must use MFA for network access to non-privileged accounts

Verify CAC/Alt. Token required for non-privileged network access. N/A if not PK-enabled or public data.

V-69537 (SV-222527) - medium - App must use MFA (Alt. Token) for local access to privileged accounts

Verify local admin access requires Alt. Token authentication.

V-69539 (SV-222528) - medium - App must use MFA for local access to non-privileged accounts

Verify CAC/Alt. Token required for local non-privileged access. N/A if not PKI-enabled or public data.

V-69541 (SV-222529) - medium - Users must authenticate individually before using group authenticator

Verify individual auth required before group/shared account access. N/A if no group accounts.

V-69543 (SV-222530) - medium - App must use replay-resistant auth for privileged network access

Verify TLSv1.2+, Kerberos, IPSEC, or SSH protects privileged access. Check scan results for replay vulnerabilities.

V-69545 (SV-222531) - medium - App must use replay-resistant auth for non-privileged network access

Verify TLSv1.2+, Kerberos, IPSEC, or SSH protects non-privileged access. N/A if public data or no DoD CAC eligibility.

V-69547 (SV-222532) - medium - App must use mutual authentication when required by policy/data owner

If mutual auth required, verify server requests client certificates and CLIENT-CERT login-config is set.

V-69549 (SV-222533) - medium - App must authenticate all network connected endpoint devices

If app uses web services/SOA, verify Client Certificate auth (not Basic Auth). N/A if end-user interactive only.

V-69551 (SV-222534) - medium - SOA handling non-releasable data must use mutual SSL/TLS

If SOA processes non-releasable data, verify mutual TLS client certificate authentication. N/A otherwise.

V-69553 (SV-222535) - medium - Disable device identifiers after 35 days inactivity

Verify device accounts disabled after 35 days inactivity. N/A if using PKI certs or no device authentication.

V-69555 (SV-222536) - high - App must enforce minimum 15-character password length

Attempt password shorter than 15 chars. Verify rejected. N/A if app does not use passwords.

V-69557 (SV-222537) - medium - App must require at least one uppercase character in password

Attempt password without uppercase. Verify rejected. N/A if app does not use passwords.

V-69559 (SV-222538) - medium - App must require at least one lowercase character in password

Attempt password without lowercase. Verify rejected. N/A if app does not use passwords.

V-69561 (SV-222539) - medium - App must require at least one numeric character in password

Attempt password without number. Verify rejected. N/A if app does not use passwords.

V-69563 (SV-222540) - medium - App must require at least one special character in password

Attempt password without special char. Verify rejected. N/A if app does not use passwords.

V-69565 (SV-222541) - medium - App must require change of at least 8 characters on password change

Change password with fewer than 8 character differences. Verify rejected. N/A if no passwords.

V-69567 (SV-222542) - high - App must only store cryptographic representations of passwords

Review password storage. Verify hashed (not MD5). No readable passwords. N/A if app does not use passwords.

V-69569 (SV-222543) - high - App must transmit only cryptographically-protected passwords

Verify TLS/SSL protects password transmission (HTTPS lock icon). N/A if app does not use passwords.

V-69571 (SV-222544) - medium - App must enforce 24-hour minimum password lifetime

Attempt password change twice within 24 hours. Verify second change rejected. N/A if no passwords.

V-69573 (SV-222545) - medium - App must enforce 60-day maximum password lifetime

Review password settings. Verify passwords expire after 60 days. N/A if app does not use passwords.

V-69575 (SV-222546) - medium - App must prohibit password reuse for 5 generations minimum

Verify password reuse prohibited for at least 5 previous passwords. N/A if no passwords.

V-69577 (SV-222547) - medium - App must allow temp password with immediate change on first use

Create user with temp password. Verify forced change on first login. N/A if no passwords.

V-70145 (SV-222548) - medium - Password changeable only by owner or admin

As User A, attempt to change User B password. Verify denied. N/A if no passwords.

V-70147 (SV-222549) - medium - App must terminate sessions upon account deletion

Delete test account while session active. Verify session terminates immediately.

V-70149 (SV-222550) - high - PKI auth must validate cert path to accepted trust anchor

Verify app constructs certification path through intermediary CAs to trusted root anchor.

V-70151 (SV-222551) - high - PKI auth must enforce authorized private key access

Verify private key access restricted by file permissions or app controls. N/A if no private keys.

V-70153 (SV-222552) - medium - PKI auth must map identity to individual user or group

Verify app maps certificate data to individual user identities in logs.

V-70155 (SV-222553) - medium - PKI auth must implement local CRL cache

Verify CRL import process and app checks CRL when OCSP unavailable. N/A if SIPRNet without root CA access.

V-70157 (SV-222554) - high - App must not display passwords/PINs as clear text

Enter password and verify input is obfuscated. Copy and paste obfuscated text - verify no clear text revealed.

V-70159 (SV-222555) - high - App must use FIPS-validated crypto modules for authentication

Verify crypto module is on FIPS 140-2 approved list at csrc.nist.gov. N/A if no crypto module authentication.

V-70161 (SV-222556) - medium - App must uniquely identify/authenticate non-organizational users

Verify non-org users are uniquely identified and authenticated. N/A if no non-org users.

V-70163 (SV-222557) - medium - App must accept PIV from other federal agencies

Verify app accepts PIV credentials from other agencies. N/A if not for federal partners or SIPRNet only.

V-70165 (SV-222558) - medium - App must electronically verify PIV from other federal agencies

Verify app validates PIV from other agencies. N/A if not for federal partners or SIPRNet only.

V-70167 (SV-222559) - medium - App must accept FICAM-approved third-party credentials

Verify FICAM-approved credentials accepted for third-party access. N/A if not for federal partners or SIPRNet.

V-70169 (SV-222560) - medium - App must conform to FICAM-issued profiles (SAML/OpenID)

Verify conformance to FICAM profiles when using external identity providers. N/A if not a service provider.

V-70171 (SV-222561) - medium - Non-local maintenance sessions must be audited

Perform remote maintenance tasks and verify actions are logged. N/A if no remote maintenance capability.

V-70175 (SV-222562) - medium - Non-local maintenance must use crypto for integrity

Verify remote maintenance sessions use TLS/SSL encryption. N/A if no remote maintenance capability.

V-70177 (SV-222563) - medium - Non-local maintenance must use crypto for confidentiality

Verify remote maintenance sessions use TLS/SSL encryption. N/A if no remote maintenance capability.

V-70179 (SV-222564) - medium - Non-local maintenance must verify remote disconnection

End maintenance session. Use netstat to verify network connections terminate. Check logs for disconnect event.

V-70181 (SV-222565) - medium - Non-local maintenance must use strong authenticators (CAC)

Verify CAC required for remote maintenance sessions. N/A if no remote maintenance capability.

V-70183 (SV-222566) - medium - App must terminate sessions when non-local maintenance completes

Verify admin idle timeout is 10 min and user idle timeout is 15 min.

V-70185 (SV-222567) - medium - App must not be vulnerable to race conditions

Review code analysis results for race condition vulnerabilities. N/A if COTS without code review access.

V-70187 (SV-222568) - medium - App must terminate network connections at end of session

Monitor with netstat. End session and verify connections close. Document any exceptions with mitigations.

V-70191 (SV-222570) - medium - App must use FIPS-validated crypto for signing components

Verify code signing uses FIPS-validated modules. No SHA1 or MD5. N/A if signing not required with risk acceptance.

V-70193 (SV-222571) - medium - App must use FIPS-validated crypto for hashing

Verify hashing uses FIPS-validated modules. No MD5 or SHA1. SHA-384+ required for NSS.

V-70195 (SV-222572) - medium - App must use FIPS-validated crypto for unclassified data protection

Verify crypto modules are FIPS 140-2 validated at csrc.nist.gov for all cryptographic operations.

V-70197 (SV-222573) - medium - SAML assertions must use FIPS-approved random numbers for SessionIndex

Verify FIPS-validated random number generator for SAML SessionIndex. N/A if no SAML assertions.

V-70199 (SV-222574) - medium - User interface must be separated from data/management interfaces

Verify app provides separate user and management interfaces (physical or virtual separation).

V-70201 (SV-222575) - medium - App must set HTTPOnly flag on session cookies

Use browser dev tools (F12) to inspect session cookies. Verify HttpOnly flag is set.

V-70203 (SV-222576) - medium - App must set Secure flag on session cookies

Inspect session cookies via browser dev tools. Verify Secure flag is set.

V-70205 (SV-222577) - high - App must not expose session IDs

Verify all session ID traffic is encrypted via TLS/SSL on all communication paths point-to-point.

V-70207 (SV-222578) - high - App must destroy session ID/cookie on logoff or browser close

Log out and check cookies. Verify session cookies destroyed. Close browser and recheck.

V-70209 (SV-222579) - medium - App must use system-generated session IDs protecting against fixation

Verify session IDs are newly generated on each login and not reused after logout.

V-70211 (SV-222580) - medium - App must validate session identifiers

Verify app validates session IDs on each request per framework configuration.

V-70213 (SV-222581) - medium - App must not use URL-embedded session IDs

Verify session IDs transmitted via cookies, not URL parameters or URL rewriting.

V-70215 (SV-222582) - medium - App must not re-use or recycle session IDs

Verify session IDs are unique and not reused after user logout.

V-70217 (SV-222583) - medium - App must use FIPS 140-2/3 random number generator for session IDs

Verify session ID generation uses FIPS 140-2/140-3 approved random number generator.

V-70219 (SV-222584) - medium - App must only use DoD-approved CAs for protected sessions

View certificate in browser. Verify issuer is DoD-approved PKI or ECA Certificate Authority.

V-70221 (SV-222585) - high - App must fail to secure state on init/shutdown/abort failure

Simulate failure (stop services). Verify DB requires auth, source files inaccessible, data files unopenable.

V-70223 (SV-222586) - medium - App must preserve failure info for root cause and recovery

Verify app logs diagnostic info for root cause analysis. Verify recovery procedures are documented.

V-70225 (SV-222587) - medium - App must protect confidentiality and integrity of stored info

Verify stored data protections match data owner requirements. Demonstrate protection methods for classified/CUI.

V-70227 (SV-222588) - high - App must use approved crypto to prevent unauthorized modification at rest

Verify encryption protects data at rest per requirements. N/A if publicly releasable data only.

V-70229 (SV-222589) - high - App must use appropriate crypto for stored DoD information

Verify encryption commensurate with classification. Type 1/Suite B for classified. N/A if publicly releasable.

V-70231 (SV-222590) - medium - App must isolate security functions from non-security functions

Verify access controls (RBAC/ACL/MAC) protect security config settings from unauthorized modification.

V-70233 (SV-222591) - medium - App must maintain separate execution domain per process

Verify app processes run in separate domains/sandboxes. Check OS processes for separation.

V-70235 (SV-222592) - medium - App must prevent unauthorized info transfer via shared resources

If app shares system resources, verify security boundary prevents unauthorized cross-app access.

V-70237 (SV-222593) - medium - XML apps must mitigate DoS using filters, parser options, or gateways

If app uses XML, verify: recursive payload validation, oversized payload limits, entity expansion prevention. N/A if no XML.

V-70239 (SV-222594) - medium - App must restrict DoS attack capability against itself and others

Review vulnerability/penetration test results. Verify app not susceptible to DoS and cannot be weaponized.

V-70241 (SV-222595) - medium - HA web service design must include redundancy mechanisms

If designated HA, verify load balancers, redundant servers, redundant circuits, or clustering. N/A if not HA.

V-70245 (SV-222596) - high - App must protect confidentiality and integrity of transmitted info

Verify all app communications use TLS, IPsec, or approved encryption mechanisms.

V-70247 (SV-222597) - medium - App must use crypto to prevent unauthorized disclosure in transmission

Verify point-to-point TLS or per-message encryption based on app architecture. N/A if PDS protected.

V-70249 (SV-222598) - medium - App must protect confidentiality/integrity during prep for transmission

Verify TLS encryption active before data sent. Check for automatic HTTPS redirect.

V-70251 (SV-222599) - medium - App must protect confidentiality/integrity during reception

Verify TLS encryption protects received data including inter-tier communications.

V-70253 (SV-222600) - medium - App must not disclose unnecessary information to users

Review all screens as non-privileged user. No DB version, server info, or technical details should appear.

V-70255 (SV-222601) - high - App must not store sensitive information in hidden fields

Review vulnerability scan/code review for hidden fields. No auth or session data in hidden fields.

V-70257 (SV-222602) - high - App must protect from Cross-Site Scripting (XSS)

Test input fields with <script>alert('XSS')</script>. No popup should appear. Verify scan includes XSS tests.

V-70259 (SV-222603) - medium - App must protect from Cross-Site Request Forgery (CSRF)

Review scan results for CSRF. Verify anti-CSRF tokens and HTTP referrer validation are implemented.

V-70261 (SV-222604) - high - App must protect from command injection

Verify vulnerability scan tests for command injection. Review OWASP OTG-INPVAL-013 for manual tests.

V-70263 (SV-222605) - medium - App must protect from canonical representation vulnerabilities

Verify scan/code review tests for canonicalization and character set handling issues.

V-70265 (SV-222606) - medium - App must validate all input

Verify vulnerability scan includes input validation and fuzzing. Test all data entry fields.

V-70267 (SV-222607) - high - App must not be vulnerable to SQL Injection

Verify vulnerability scan tests for SQL injection across all DB interfaces.

V-70269 (SV-222608) - high - App must not be vulnerable to XML-oriented attacks

If app uses XML, verify scan tests for XML/XPath injection, XML spoofing, entity attacks. N/A if no XML.

V-70271 (SV-222609) - high - App must not be subject to input handling vulnerabilities

Verify scan tests for input validation issues. Remediate high-risk findings or obtain ISSO risk acceptance.

V-70273 (SV-222610) - medium - Error messages must not reveal exploitable info to non-privileged users

Trigger errors as non-privileged user. Verify no variable names, SQL, paths, or source code disclosed.

V-70275 (SV-222611) - medium - Detailed error messages only for ISSO/ISSM/SA

Trigger errors as non-privileged vs privileged user. Detailed errors visible only to privileged users.

V-70277 (SV-222612) - high - App must not be vulnerable to overflow attacks

Verify code analysis tests for buffer, stack, heap, integer, and format string overflows. Remediate findings.

V-70279 (SV-222613) - medium - App must remove old components after updates

After updates, check for old version files on disk. Remove any remaining old components.

V-70281 (SV-222614) - medium - Security updates and patches must be kept up to date

Verify patches checked weekly and applied per IAVMs, CTOs, DTMs, or POA&Ms.

V-70283 (SV-222615) - medium - App must verify correct operation of security functions

If app is designed for security function testing, verify it validates correct operation. N/A otherwise.

V-70285 (SV-222616) - medium - Security function verification on startup/restart/command/30 days

Verify security function testing runs on startup, restart, and on privileged command. N/A if not designed for this.

V-70289 (SV-222618) - medium - Unsigned Category 1A mobile code must not be used

Add app URL to Trusted Sites. Test app functions. Browser should indicate code is digitally signed. N/A if no mobile code.

V-70291 (SV-222619) - medium - Account management process must be implemented and verified

Verify documented process for account creation, termination, expiration. Verify departed personnel accounts removed.

V-70293 (SV-222620) - high - Tiered app web servers must be on separate network segment in DMZ

If in DoD DMZ, verify web/app/DB servers on separate network segments per DMZ STIG. N/A if not in DMZ.

V-70295 (SV-222621) - medium - Audit trails retained 30 months (non-SAMI) or 5 years (SAMI)

Verify retention: 12 months active + 18 months cold storage for non-SAMI; 5 years for SAMI data.

V-70297 (SV-222622) - medium - Audit trails must be reviewed periodically per documentation

Verify documented schedule for audit log review and evidence of most recent review.

V-70301 (SV-222623) - medium - Suspected IA policy violations must be reported per DoD procedures

Verify documented policy exists for reporting IA violations.

V-70303 (SV-222624) - medium - Active vulnerability testing must be performed

Verify scan and fuzz test results exist. Config must cover all app components. Critical vulns 21+ days old = finding.

V-70307 (SV-222625) - medium - Execution flow diagrams must address deadlock/recursion in web services

If app deploys web services, verify documentation addresses deadlock mitigation. N/A if no web services developed.

V-70309 (SV-222626) - medium - Config/control files must not be in same directory as user data

Verify app config files and user data are in separate directories. Check file permissions restrict user access to config.

V-70311 (SV-222627) - medium - Use third-party guidance if no DoD STIG/NSA guide available

If no STIG exists, verify config follows vendor guidance, commercial best practices, or independent testing results.

V-70313 (SV-222628) - medium - Ports/protocols must be submitted through DoD PPSM

Verify app ports/protocols comply with PPSM CAL at https://cyber.mil/ppsm/cal/.

V-70317 (SV-222629) - medium - App must be registered with DoD Ports and Protocols Database

Verify app and all ports are registered in the DoD Ports and Protocols Database for production.

V-70339 (SV-222630) - medium - CM repository must be patched and STIG compliant

Verify CM system has latest security patches and relevant STIGs applied. N/A if no in-house development/CM.

V-70341 (SV-222631) - medium - CM repository access privileges reviewed every 3 months

Verify CM access privileges reviewed within last 3 months. N/A if no in-house CM repository.

V-70343 (SV-222632) - medium - SCM plan must describe config control and change management

Verify SCM plan covers objects, roles, responsibilities, tools, baselines, access controls, audit. N/A if no in-house dev.

V-70345 (SV-222633) - medium - CCB must meet at least every release cycle

Verify CCB exists with charter and evidence of meeting before last release. N/A if no in-house development.

V-70347 (SV-222634) - medium - App services and interfaces must be IPv6 compatible

Verify app complies with DoD IPv6 Standards Profile for IPv6 Capable Products.

V-70349 (SV-222635) - medium - Critical/HA apps must not be on general purpose machines

Verify mission-critical app is not co-hosted with non-mission-critical applications.

V-70351 (SV-222636) - medium - Contingency plan must exist per DoD policy for availability level

Verify contingency plan: HA=immediate transfer, moderate=12hr resume, low=5-30 day partial resume.

V-70353 (SV-222637) - medium - Recovery procedures must enable secure and verifiable recovery

Verify disaster recovery plan includes the application and documents trusted recovery considerations.

V-70355 (SV-222638) - medium - Data backup at required intervals per DoD policy and risk level

Verify backups per risk: low=weekly, moderate=daily+offsite, high=redundant systems with 6-month testing.

V-70357 (SV-222639) - medium - Backup copies in fire-rated container or stored offsite

Verify app software/source code backup is in fire-rated container or stored offsite from operational environment.

V-70359 (SV-222640) - medium - Backup/restoration assets must be physically and technically protected

Verify backup devices and media are included in recovery procedures and stored separately from primary assets.

V-70361 (SV-222641) - medium - App must encrypt key exchange and authenticate endpoints

Verify FIPS 140-2 validated crypto for key exchange. N/A if no key exchange implemented.

V-70363 (SV-222642) - high - App must not contain embedded authentication data

Search config files, scripts, HTML, ASP/ASPX for embedded passwords/certs. Verify restricted file permissions.

V-70365 (SV-222643) - high - App must mark sensitive/classified output when required

Verify markings on screens/reports for classified/CUI data (top and bottom minimum). Manual marking procedures acceptable.

V-70369 (SV-222645) - medium - App files must be cryptographically hashed before deployment

Verify hash validation process. Use Get-FileHash (SHA256) to validate against vendor-provided hashes.

V-70371 (SV-222646) - medium - Security tester must be designated for flaw testing

Verify designated security testers exist in addition to functional testers. N/A if no in-house development.

V-70375 (SV-222648) - medium - Application code review must be performed

Verify code reviews cover: format strings, memory leaks, buffer overflows, race conditions, SQL injection, dead code. N/A if no in-house dev.

V-70379 (SV-222650) - medium - Code review flaws must be tracked in defect tracking system

Verify CM repository captures code review defects. N/A if no in-house development.

V-70381 (SV-222651) - medium - Changes must be assessed for IA/accreditation impact before implementation

Verify CCB or similar process evaluates IA impact before implementing changes.

V-70383 (SV-222652) - medium - Security flaws must be addressed in project plan

Verify security flaws are tracked in project plan. N/A if no in-house development.

V-70389 (SV-222655) - medium - Threat models documented and reviewed per release

Verify threat model with: threats, vulnerabilities, countermeasures, mitigations, ISSO/ISSM approval. N/A if no in-house dev.

V-70391 (SV-222656) - medium - App must not have error handling vulnerabilities

Review security scan/code analysis for error handling issues. Verify proper exception handling throughout.

V-70393 (SV-222657) - medium - Dev team must provide application incident response plan

Verify plan tracks/confirms vulns, tracks remediation, notifies users of updates. N/A if COTS without dev access.

V-70395 (SV-222658) - high - All products must be supported by vendor or development team

Verify all app components are vendor-supported. Check vendor website for current version support status.

V-70397 (SV-222659) - high - App must be decommissioned when support is no longer available

Verify all app components are under active maintenance contract. Decommission if support has ended.

V-70401 (SV-222661) - medium - Unnecessary built-in application accounts must be disabled

Review account list for vendor default accounts (e.g., Oracle, Tivoli). Disable unnecessary; change passwords on required.

V-70403 (SV-222662) - high - Default passwords must be changed

Search Internet for app name + 'default password'. Attempt authentication with published defaults. Change if successful.

V-70405 (SV-222663) - medium - Application Configuration Guide must exist

Verify guide covers: encryption, PKI, passwords, auditing, AD, backup, deployment, network, security assumptions.

V-70407 (SV-222664) - medium - Security Classification Guide must exist for classified data apps

If classified data, verify guide with data elements and classifications per DOD 5200.01 Vol 1. N/A if unclassified.

V-70409 (SV-222665) - medium - Uncategorized or emerging mobile code must not be used

Identify mobile code types. Verify waiver and risk acceptance for any uncategorized mobile code.

V-70411 (SV-222666) - medium - Production DB exports must have credentials/sensitive data removed

If prod data exported to test/dev, verify sensitive data is sanitized before or immediately after import. N/A if no exports.

V-70413 (SV-222667) - medium - DoS attack protections must be implemented per threat model

Review threat model for DoS threats. Verify identified mitigations are implemented. N/A if no DoS threats identified.

V-70415 (SV-222668) - medium - System must alert administrator on low resource conditions

Verify automated continuous monitoring with alerts for low resources and unusual/inappropriate activity.

V-70421 (SV-222671) - medium - Public-facing apps must route through DMZ

If app is publicly accessible, verify traffic is routed through a DMZ.

V-70425 (SV-222673) - medium - All program staff must receive annual security training

Verify annual security training for managers, designers, developers, testers (beyond DoD 8570). N/A if no in-house dev.

V-70189 (SV-265634) - medium - App must use NSA-approved crypto for classified information

If classified data: NIST FIPS 140-2 for non-SAMI, NSA Type 1 for SAMI. N/A if unclassified.

Generated by Windows 11 STIG Compliance Checker v2.0 | 550 rules checked